Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет Информационных технологий и компьютерной безопасности
Кафедра Систем информационной безопасности
Направление подготовки (специальность) 10.05.03 Информационная безопасность автоматизированных систем
(код и наименование направления подготовки)
Профиль/программа/направленность Обеспечение информационной безопасности распределённых информационных систем

ВЫПУСКНАЯ КВАЛИФИКАЦИОННАЯ РАБОТА
Дипломная работа
(вид выпускной квалификационной работы – бакалаврская работа, дипломная работа (проект), магистерская диссертация)

Сухорукова Егора Дмитриевича
(фамилия, имя, отчество обучающегося)

Тема: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Злоумышленник посередине»

Состав выпускной квалификационной работы:
Расчетно-пояснительная записка на 86 страницах
Графическая часть на _____ листах

Расчетно-пояснительная записка к выпускной квалификационной работе:

Заведующий кафедрой _____ (А.Г. Остапенко)
(подпись) (инициалы, фамилия)

Руководитель _____ (В.И. Белоножкин)
(подпись) (инициалы, фамилия)

Консультанты:
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

Обучающийся _____ Е.Д. Сухоруков
(подпись) (инициалы, фамилия)

«02» 07 2025 г.

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет Информационных технологий и компьютерной безопасности

Кафедра Систем информационной безопасности

Направление подготовки/специальность 10.05.03 «Информационная безопасность автоматизированных систем»
(код, наименование)

Профиль/программа/направленность Обеспечение информационной безопасности распределённых информационных систем

Утверждаю _____
(дата)

Зав.кафедрой _____
(подпись)

ЗАДАНИЕ
ПО ПОДГОТОВКЕ ВЫПУСКНОЙ КВАЛИФИКАЦИОННОЙ РАБОТЫ

Дипломная работа
дипломная работа (проект), бакалаврская работа, магистерская диссертация

Обучающемуся Сухорукову Егору Дмитриевичу
фамилия, имя, отчество

1. Тема: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Злоумышленник посередине»

ФГБОУ ВО «ВГТУ», ВГТУ
по заданию какой организации выполняется работа

приказ №01-1-10/3-2979 от 25.06.2025
утверждена приказом по университету

2. Срок сдачи обучающимся выпускной квалификационной работы 02.07.25

3. Исходные данные

4. Краткое содержание выпускной квалификационной работы

Раздел 1. Анализ риск-калькуляторов и баз данных ИБ
перечень подлежащих разработке в выпускной квалификационной работе вопросов

Раздел 2. Разработка моделей кибератак класса «Злоумышленник посередине»

Раздел 3. Оценка рисков успешной реализации атак класса «Злоумышленник посередине»

Раздел 4. Разработка организационно-правовых регламентов защиты для снижения влияния рисков кибератак класса «Злоумышленник посередине»

5. Перечень графического материала (с точным указанием обязательных чертежей по разделам)

6. Консультанты (с указанием относящихся к ним разделов)

График выполнения выпускной квалификационной работы

№ п/п	Наименование разделов выпускной квалификационной работы	Срок выполнения этапов работы
1	Введение	22.03.25 – 22.05.25
2	Анализ риск-калькуляторов и баз данных ИБ	22.03.25 – 22.05.25
3	Разработка моделей кибератак класса «Злоумышленник посередине»	23.05.25 – 31.05.25
4	Оценка рисков успешной реализации атак класса «Злоумышленник посередине»	01.06.25 – 12.06.25
5	Разработка организационно-правовых регламентов защиты для снижения влияния рисков кибератак класса «Злоумышленник посередине»	13.06.25 – 24.06.25
6	Заключение	25.06.25 – 02.07.25

Руководитель _____
(подпись)

Дата выдачи задания 22.03.25

Задание принял к исполнению 22.03.25
(дата)

Подпись обучающегося _____

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение
высшего образования
«Воронежский государственный технический университет»

АННОТАЦИЯ
выпускной квалификационной работы

Обучающегося Сухорукова Егора Дмитриевича
Тема ВКР: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Злоумышленник посередине»

Характеристика выпускной квалификационной работы

Актуальность исследования

Исследование решает проблему отсутствия работ, связанных с оценкой и регулированием рисков успешности кибератак класса «Злоумышленник посередине». Актуальность обусловлена стремительным ростом количества данных кибератак.

Задачи, решаемые в ВКР

– Выполнение всестороннего анализа разнородных открытых источников информации о киберугрозах и существующих методиках оценивания рисков с последующей систематизацией их применимости для защиты автоматизированных информационных систем от атак класса «злоумышленник посередине»;

– Составление перечня соответствий между CVE-идентификаторами уязвимостей и CAPEC-шаблонами класса «Злоумышленник посередине» с последующей декомпозицией этих шаблонов на техники MITRE ATT&CK;

– Оценка вероятности успешной реализации кибератак класса «Злоумышленник посередине» на автоматизированные информационные системы и анализ возможных вариантов их реализации с учётом потенциального ущерба;

– разработка организационных регламентов с контрмерами для минимизации рисков и усиления защиты АИС от атак класса «Злоумышленник посередине».

Структура ВКР

Введение

Глава 1. Анализ риск-калькуляторов и баз данных ИБ

Глава 2. Разработка моделей кибератак класса «Злоумышленник посередине»

Глава 3. Оценка рисков успешной реализации атак класса «Злоумышленник посередине»

Глава 4. Разработка организационно-правовых регламентов защиты для снижения влияния рисков кибератак класса «Злоумышленник посередине»

Заключение

Список литературы

Приложение А

Приложение Б

Краткая характеристика полученных результатов *(по разделам ВКР)*

Раздел 1. Анализ риск-калькуляторов и баз данных ИБ.

Проанализированы существующие базы данных киберугроз и инструменты риск-оценки;

Раздел 2. Разработка моделей кибератак класса «Злоумышленник посередине».

Созданы таблицы соответствия шаблонов-уязвимостей и относящихся к ним тактик с техниками;

Раздел 3. Оценка рисков успешной реализации атак класса «Злоумышленник посередине».

Проведена оценка риска единичных атак, а также созданы и разобраны возможные сценарии атак, включая экстремальные;

Раздел 4. Разработка организационно-правовых регламентов защиты для снижения влияния рисков кибератак класса «Злоумышленник посередине»

Разработаны организационно-правовые регламенты для устранения уязвимостей и понижения значения риска.

Автор ВКР_____Сухоруков Егор Дмитриевич
(подпись)

СОДЕРЖАНИЕ

ВВЕДЕНИЕ 7

1 Анализ риск – калькуляторов и баз данных ИБ 13

1.1 Анализ баз данных 13

1.1 Сравнительная характеристика риск-калькуляторов 15

2 Разработка моделей кибератак класса «Злоумышленник посередине» 24

2.1 Установление соответствия между возможными CAPEC-шаблонами атак и эксплуатируемыми ими уязвимостями 24

2.2 Разработка моделей сценариев реализации шаблонов атак с использованием техник MITRE ATT&CK. 34

3 Оценка рисков успешной реализации атак класса «Злоумышленник посередине» 43

3.1 Оценка критичности эксплуатируемых уязвимостей 43

3.2 Расчёт рисков реализации сценариев атак 50

4 Разработка организационно-правовых регламентов защиты для снижения рисков реализации атак класса «Злоумышленник посередине» 64

ЗАКЛЮЧЕНИЕ 67

СПИСОК ЛИТЕРАТУРЫ 69

ПРИЛОЖЕНИЕ А 73

ПРИЛОЖЕНИЕ Б 80

ВВЕДЕНИЕ

Современное киберпространство характеризуется постоянным усложнением и увеличением числа угроз, направленных на компрометацию информационных систем, хищение данных и дестабилизацию их работы. Согласно опросам, почти четверть российских компаний сталкиваются с риском утечки информации, из которых 15 % уже понесли серьёзные убытки, 70 % организаций подвергались заражению вредоносным ПО, 73 % – несанкционированному доступу к данным, а 62 % – DDoS-атакам. При этом в 54 % инцидентов ущерб наносили внешние злоумышленники, в 30 % – внутренние, и в 15 % случаев источник угроз оставался неизвестным. В то же время лишь 40 % крупных предприятий оснащены специализированными подразделениями информационной безопасности, а в 55 % защиту информации обеспечивают штатные IT-службы, что не позволяет кардинально повысить устойчивость к атакам.

Несмотря на достаточно длительное существование класса компьютерных атак класса «Злоумышленник посередине» (MitM), при которых осуществляется умышленное внедрение в канал связи между двумя компонентами (например, клиентом и сервером) для перехвата или модификации передаваемых данных, проблема защиты от них не теряет актуальности с учетом постоянного развития сетевых технологий и атакующих техник, которое приводит к расширению множеств и уязвимостей инфраструктуры и векторов атак [1, 2]. Так, например, повсеместное использование беспроводных сетей существенно расширяет возможность перехвата, подмены и блокирования сетевого трафика в телекоммуникационных системах (ТКС), на основе которых строятся современные автоматизированные информационные системы (АИС), что соответственно повышает риски нарушения конфиденциальности, целостности и доступности циркулирующей в них информации и требует более системного применения программно-технических и организационно-правовых мер защиты. Комбинации атакующих техник и уязвимостей ТКС порождают множество сценариев MitM-атак, для эффективного противодействия которым становится необходимым проведение математического моделирования в сочетании с риск-анализом.

По данным отчёта JumpCloud, атаки типа MitM составляют около 19 % всех успешных кибератак в текущем году, а число скомпрометированных электронных почтовых ящиков выросло на 35 % с 2021 года. Анализ IBM X-Force показывает, что в 35 % случаев эксплуатации уязвимостей были использованы техники «Злоумышленник посередине». При этом более половины таких атак нацелены на перехват конфиденциальных данных – учётных записей и банковской информации, а ежегодный глобальный ущерб от MitM оценивается в 2 млрд USD.

Для реализации MitM-атак злоумышленники часто используют ARP-подмену, DNS-спуфинг и другие механизмы, перенаправляя трафик через контролируемые ими узлы и получая доступ к данным. В отдельных случаях применяются приёмы SSL/TLS stripping и подмена сертификатов, что позволяет обходить криптографическую защиту каналов связи.

Несмотря на развитие инструментов обнаружения и противодействия – от сетевых экранов и IDS до сертификатно-ориентированных решений, наносимый атаками «Злоумышленник посередине» ущерб продолжает расти. Это подчёркивает необходимость разработки универсальных методик оценки рисков и комплексной стратегии противодействия атакам класса «Злоумышленник посередине» в рамках единой системы управления кибербезопасностью.

Исследования в сфере риск-анализа различных классов атак кафедры систем информационной безопасности ВГТУ позволили выработать методики построения атласа кибератак [1], расчёта метрик уязвимостей [3, 4, 16, 17], анализа рисколандшафтов единичных [8, 9] и массированных [13] атак, а также разработать нейросетевые методы противодействия им [7, 10, 11, 14, 15]. В то же время, не все классы атак (и в том числе, MitM-атаки) исследованы с требуемым уровнем детализации риск-моделей, что и определяет актуальность настоящего исследования.

Объектом исследования выступают автоматизированные информационные системы, подвергающиеся атакам класса «Злоумышленник посередине».

Предметом исследования являются процессы обеспечения информационной безопасности автоматизированных информационных систем при воздействии

кибератак класса «Злоумышленник посередине», включающие анализ взаимосвязей между шаблонами атак, техниками и эксплуатируемыми уязвимостями, моделирование сценариев атак, оценку рисков с использованием различных метрик, а также разработку рекомендаций по противодействию подобным инцидентам на основе анализа вероятности эксплуатации уязвимостей и потенциального ущерба.

Цель исследования состоит в повышении защищенности автоматизированных информационных систем от атак класса «Злоумышленник посередине».

Исследование аналогов показало наличие ряда **противоречий** между:

– необходимостью наличия достаточного объема данных и иных актуальных сведений относительно пар «атака - уязвимость» для атакуемых автоматизированных информационных систем и отсутствием такового для атак класса «Злоумышленник посередине»;

– потребностью установления соответствия элементов множества рассматриваемого класса атак и уязвимостей, обусловленных отсутствием таковых в проектном пространстве обеспечения безопасности защищенных автоматизированных информационных систем;

– существующей методологией вероятностной оценки опасности кибератак класса «Злоумышленник посередине» использующей калькуляторы CVSS, EPSS, OWASP и необходимостью риск-анализа вторжений в автоматизированную информационную систему, которая отсутствует в сложившихся подходах;

– несовершенством процедур регламентации противодействия кибератакам класса «Злоумышленник посередине» и необходимостью осуществлять такую проектную деятельность в соответствии с этапом реализации вторжения злоумышленника в автоматизированные информационные системы.

Для разрешения перечисленных противоречий и достижения поставленной цели необходимо решить следующие **задачи**:

– организация, сбор открытых интернет-источников и суммаризации данных относительно пар «атака – уязвимость» в отношении автоматизированных информационных систем;

– установление соответствия между кибератаками класса «Злоумышленник посередине» и уязвимостями в автоматизированных информационных системах, включая их сценарное описание;

– оценка рисков нарушения информационной безопасности посредством кибератак класса «Злоумышленник посередине» на уязвимости в автоматизированных информационных системах;

– формирование регламентов реагирования и ликвидации последствий в отношении кибератак класса «Злоумышленник посередине» на уязвимости в автоматизированных информационных системах.

На защиту будут вынесены следующие **результаты**:

– структурированная база данных кибератак класса «Злоумышленник посередине» на АИС, аккумулирующая статистические и экспертные метрики, извлечённые из открытых интернет-источников;

– векторное представление пар «атака – уязвимость» на основе анализа стандартов CAPEC, CWE и CVE, отражающее динамику развития атак злоумышленника в ходе взаимодействия с АИС;

– методика оценки рисков нарушения информационной безопасности АИС в результате реализации кибератак класса «Злоумышленник посередине» с учётом специфики используемых злоумышленников сценариев;

– комплекс регламентов реагирования и ликвидации последствий в отношении кибератак класса «Злоумышленник посередине» на уязвимости АИС.

Новизна полученных результатов состоит в следующем:

– в отличие от аналогов, собранные данные с помощью предложенных выражений могут являться основой для вероятностного моделирования процесса реализации класса кибератак «Злоумышленник посередине», используемых в автоматизированных информационных системах, что обеспечивает основу для

комплексной оценки и регулирования рисков в сфере обеспечения кибербезопасности АИС;

– впервые для класса кибератак «Злоумышленник посередине» была предложены обобщённая графическая модель сценариев атак, которые могут быть использованы злоумышленником для вторжения в АИС;

– в отличии от аналогов предложена методика оценки рисков сценариев нарушения информационной безопасности АИС при реализации кибератак класса «Злоумышленник посередине», а также определены наиболее вероятные сценарии вторжения и сценарии максимального и минимального риска вторжения в АИС;

– для выявленных сценариев впервые предложены актуальные регламенты и методики противодействия кибератакам класса «Злоумышленник посередине».

Практическая ценность полученных результатов видится в том, что:

– созданная база данных метрик кибератак класса «Злоумышленник посередине» и уязвимостей АИС, является практической основой для риск-анализа единичных вторжений и имеет практическую возможность её расширения для соответствующих проектных ситуаций;

– сформированное множество сценариев и их риск-анализ отражает практику реализации проектной деятельности защиты АИС от атак класса «Злоумышленник посередине»;

– предоставленные оценки рисков представляют собой базу для их рецензирования при нарушении информационной безопасности АИС посредством кибератак класса «Злоумышленник посередине», в том числе путём закрытия эксплуатируемых уязвимостей АИС;

– предложенная регламентация является инструментом практического управления риск-ландшафтом успешности кибератак класса «Злоумышленник посередине» на защищаемые АИС.

Теоретическая значимость полученных результатов видится в том, что:

− сформированная база риск-метрик открыта для ее расширения на другие разновидности кибератак и прочие информационные системы, подверженные вторжению;

− разработанные сценарии атак класса «Злоумышленник посередине» в ходе проектной деятельности могут быть расширены на другие используемые тактики, либо сужены до непосредственных уязвимостей конкретно защищаемой АИС;

− представленные оценки рисков нарушения информационной безопасности посредством кибератак класса «Злоумышленник посередине», могут быть развиты для описания рисков многократных, поточных, множественных и лавинных сетевых вторжений при соответствующей модернизации методического обеспечения риск-анализа;

− в ходе развития методологии управления риск-ландшафтом успешности кибератак класса «Злоумышленник посередине» на уязвимости защищаемых АИС предоставляется возможным формирование соответствующих инструкций для специалистов по защите информации, обеспечивающих безопасность конкретных АИС.

1 Анализ риск – калькуляторов и баз данных ИБ

1.1 Анализ баз данных

В условиях стремительного развития цифровых технологий для проведения оценки критичности и дальнейшего реагирования на кибератаки класса «Злоумышленник посередине», необходимо опираться на достоверные и актуальные источники информации специализированного назначения. К таким источникам информации относятся базы данных CAPEC, MITRE ATT&CK, БДУ ФСТЭК и NVD. Эти ресурсы предоставляют систематизированные сведения о видах атак, используемых тактиках злоумышленников и выявленных уязвимостях программного обеспечения.

CAPEC – Common Attack Pattern Enumeration and Classification (Общая классификация и перечисление шаблонов атак) представляет собой базу данных, созданную организацией MITRE и поддерживаемую сообществом, для систематизации наиболее распространённых методов, применяемых злоумышленниками при проведении атак. CAPEC предоставляет обширный каталог типов атак, каждая из которых описывает конкретный способ или шаблон атаки. Использование данной классификации помогает специалистам по информационной безопасности получать подробные сведения о тактиках и методах атак на информационную систему, что в итоге используется для создания более успешных мер противодействия опасности [10].

Второй базой данных, используемой в области информационной безопасности, является MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) – глобальная доступная база данных, которая служит основой для разработки моделей киберугроз в правительственных структурах и частных секторах.

MITRE ATT&CK используется в самых разных сценариях обеспечения информационной безопасности: от категоризации, отслеживания техник и тактик,
До моделирования реальных сценариев атак для проверки защищённости.

Следующей базой данных является NVD (National Vulnerability Database) – официальная централизованная база данных, поддерживаемая «Национальным институтом стандартов и технологий» США (NIST), и играет ключевую роль в

анализе и оценке рисков, связанных с уязвимыми компонентами информационных систем [3].

NVD автоматически собирает сведения о новых распространённых уязвимостях и рисках CVE (Common Vulnerabilities and Exposures), после чего присваивается оценка по общей системе оценки уязвимости CVSS (Common Vulnerability Scoring System). База данных NVD помогает специалистам по безопасности оперативно выявлять критические уязвимости в системе и принимать необходимые меры для их сдерживания и устранения.

Отечественным аналогом международных баз данных информации о безопасности выступает база данных ФСТЭК России (БДУ ФСТЭК), которая занимается систематизациеё угроз, уязвимостей и методов защиты, соответствующих российским стандартам и нормативным требованиям. Эта база является альтернативой таким мировым ресурсам, как NVD и ATT&CK, предоставляя данные, ориентированные на российский контекст.

БДУ ФСТЭК предоставляет информацию, ориентированную на российское законодательство в сфере информационной безопасности. Ресурс является первостепенным для специалистов, работающих в государственных структурах и отечественных компаниях, которые обязаны соблюдать национальные стандарты защиты данных. База охватывает широкий спектр вопросов безопасности, включая уязвимости в операционных системах, сетевых устройствах, а также угрозы, связанные с кибератаками и другими нарушениями безопасности.

Одной из ключевых особенностей БДУ ФСТЭК является её способность интегрироваться с другими отечественными и международными источниками информации о безопасности, что способствует формированию более точной картины текущих угроз и уязвимостей. Кроме того, база данных включает рекомендации по устранению уязвимостей, что позволяет специалистам по безопасности оперативно реагировать на возникающие угрозы [3-5].

Сравнительный анализ баз данных представлен в таблице 1.

Таблица 1 – Сравнительный анализ баз данных

Параметр	CAPEC	MITRE ATT&CK	NVD	БДУ ФСТЭК
Тип данных	Шаблоны атак	Техники атак	Уязвимости	Уязвимости
Подход	Превентивный	Реактивный	Реактивный	Реактивный
Основная цель	Проектирование	Реагирование	Управление рисками	Соответствие
Уровень детализации	Высокий	Высокий	Средний	Средний

1.1 Сравнительная характеристика риск-калькуляторов

С учётом ускоренного развития информационных технологий, возрастающая сложность киберугроз заставляет организации использовать современные, эффективные методы и инструменты для обнаружения, анализа и оценки уязвимостей. Такие, как CVSS версии 3.1 и 4.0, EPSS (Exploit Prediction Scoring System), VISS (Vulnerability Impact Scoring System) и OWASP Risk Assessment Calculator.

Сегодня специалисты в области информационной безопасности могут автоматизировать процессы оценки уязвимостей, используя риск-калькуляторы, которые позволяют обрабатывать большое количество уязвимостей одновременно. В дальнейшем будет представлен анализ наиболее эффективных из этих инструментов.

Общая система оценки уязвимостей CVSS (Common Vulnerability Scoring System) представляет собой универсальный стандарт, созданный для количественной оценки уровня опасности уязвимостей. Система предоставляет возможность определить, какое воздействие может оказать уязвимость на информационную систему. Стандарт был разработан Форумом FIRST (Forum of Incident Response and Security Teams) [4-6].

CVSS 3.1 включает три ключевые группы метрик:

1) базовые метрики (Base Metrics) – описывают общие характеристики уязвимости, независимые от контекста;

2) временные метрики (Temporal Metrics) – отражают изменения уровня опасности уязвимости со временем;

3) контекстные метрики (Environmental Metrics) – учитывают специфические условия конкретной среды.

Базовые метрики характеризуют внутренние свойства уязвимости, которые остаются стабильными независимо от времени или особенностей окружения.

Базовые метрики подразделяются на два основных типа:

1) Метрики эксплуатации (Exploitability) – описывают, насколько легко уязвимость может быть использована злоумышленником;

2) Метрики воздействия (Impact) – отражают степень ущерба, который может быть нанесён информационной системе в результате эксплуатации уязвимости.

В CVSS 3.1 базовая оценка уязвимости выражается в виде числового значения и классифицируется по следующим диапазонам: 0.0 (опасность отсутствует), 0.1-3.9 (низкий уровень опасности), 4.0-6.9 (средний уровень опасности), 7.0-8.9 (высокий уровень опасности), 9.0-10.0 (критический уровень опасности).

Временные метрики отражают изменения, связанные с уязвимостью, которые могут происходить со временем, такие как появление эксплойтов или выпуск исправлений. Они включают:

1) Зрелость эксплуатационного кода (Exploit Code Maturity) - оценивает доступность эксплойта и его готовность к использованию;

2) Уровень устранения (Remediation Level) - указывает на наличие и доступность патча или других средств устранения уязвимости;

3) Уровень уверенности в отчете (Report Confidence) - определяет степень достоверности информации об уязвимости и её источника.

Контекстные метрики учитывают особенности конкретной обстановки, поскольку значимость уязвимости может варьироваться в зависимости от её окружения. Основными компонентами являются:

1) Требования к конфиденциальности (Modified Impact) - оценка влияния уязвимости на конфиденциальность, целостность и доступность с учётом специфики организации;

2) Требования защищённости (Security Requirements) - определение приоритетности защиты данных, исходя из их важности для компании.

CVSS 3.1 постепенно утрачивает свою актуальность с выходом новой версии – CVSS 4.0, которая внесла значительные изменения в способ расчета оценки CVSS, чтобы добиться желаемой точности и гибкости в расчете. Новая версия стала более контекстно ориентированной, учитывая актуальные угрозы и эксплуатационные факторы, что позволяет точнее оценивать реальные риски. Одним из важнейших изменений стало разделение понятий "тяжесть" (severity) и "риск" (risk), что позволяет лучше понимать степень воздействия уязвимости и вероятность её эксплуатации [5].

Базовые метрики CVSS 4.0 приведены в таблице 2.

Таблица 2 – Базовые метрики CVSS 4.0

Метрика	Значения	Описание
Вектор атаки (AV)	N – по сети; A – в пределах смежной сети; L – локально на хосте; P – через физический доступ.	Место, откуда злоумышленник может инициировать атаку.
Сложность атаки (AC)	L – низкая сложность; H – высокая сложность.	Сложность осуществления атаки при заданных обстоятельствах.
Требования к привилегиям (PR)	N – без привилегий; L – средняя; H – привилегированный пользователь.	Требуемые привилегии у злоумышленника перед началом атаки.
Область воздействия (S)	U – не распространяется; C – меняет границы области воздействия.	Распространяется ли влияние уязвимости за пределы первоначально затронутого компонента.
Воздействие на конфиденциальность (C)	N – нет; L – частичное; H – полное.	Влияние на конфиденциальность (доступ к данным).
Воздействие на целостность (I)	N– нет; L – частичное; H – полная потеря.	Влияние на целостность данных.

Продолжение таблицы 2

Метрика	Значения	Описание
Воздействие на доступность (A)	N – по сети; A – в пределах смежной сети; L – локально на хосте; P– через физический доступ.	Влияние на доступность ресурса/системы.

Метрики угроз в CVSS 4.0 позволяют в реальном времени оценить риск эксплуатации уязвимости, что способствует более точной приоритезации исправлений с учётом факторов текущих атак. Метрики угроз приведены таблице 3.

Таблица 3 – Метрики угроз

Метрика	Значения	Описание
EPSS (Exploit Prediction Scoring System)	0-100 (в процентах)	Вероятность того, что уязвимость будет эксплуатирована
Активная эксплуатация (Active Exploitation, AE)	Yes (Y), No (N)	Показывает, используется ли уязвимость в реальных атаках
Текущие эксплойты (Current Exploit Availability, CEA)	Yes (Y), No (N)	Указывает, существуют ли публично доступные эксплойты
Активность злоумышленников (Adversary Activity, AA)	High (H), Medium (M), Low (L)	Оценивает активность атакующих, связанных с уязвимостью

Метрики окружения в CVSS 4.0 учитывают специфичное свойства и контекст среды, в которой используется система. Характеристики метрик представлены в таблице 4.

Таблица 4 – Метрики окружения

Метрика	Значения	Описание
Область воздействия (S)	Changed (C), Unchanged (U)	Изменяется ли область воздействия при эксплуатации
Конфиденциальность (C)	None (N), Low (L), High (H)	Влияет ли уязвимость на конфиденциальность в организации

Продолжение таблицы 4

Метрика	Значения	Описание
Целостность (I)	None (N), Low (L), High (H)	Влияет ли уязвимость на целостность критических данных
Доступность (A)	None (N), Low (L), High (H)	Влияет ли уязвимость на доступность системы

Дополнительные метрики в CVSS 4.0 вводят ряд параметров, которые не являются частью стандартной схемы оценки, но могут быть полезны для более глубокого анализа. Эти параметры представлены в таблице 5.

Таблица 5 – Дополнительные метрики

Метрика	Значения	Описание
Отчёт об уязвимости (Vulnerability Report, VR)	Open, Closed	Показывает, открыт ли отчёт об уязвимости
Публичное раскрытие (Public Disclosure, PD)	Yes (Y), No (N)	Указывает, известна ли уязвимость публично
Критичность бизнеса (Business Criticality, BC)	Low (L), Medium (M), High (H)	Показывает, как сильно уязвимость влияет на бизнес

CVSS пользуется высокой востребованностью и является основой для множества калькуляторов, таких как HVSS, EPSS и другие. Его популярность объясняется стандартизированным подходом, универсальностью и возможностью сравнивать уязвимости, что способствует более точному определению их приоритетности [2-4].

Ещё одним важным инструментом является риск-калькулятор EPSS (Exploit Prediction Scoring System), который предназначен для прогнозирования вероятности эксплуатации уязвимости. Этот инструмент помогает лучше понять, насколько вероятно, что уязвимость будет использована злоумышленниками в реальной атаке.

EPSS был разработан с целью дополнить существующие системы оценки уязвимостей, такие как CVSS, и предоставить более точную информацию о рисках.

EPSS использует статистические модели для анализа данных об уязвимостях, связанных с ними событиях и факторов риска. В основе этого инструмента лежат байесовские модели вероятности, а также анализ взаимосвязей между уязвимостями и данными о кибератаках, что позволяет более точно прогнозировать вероятность их эксплуатации.

При работе с EPSS стоит учитывать ряд следующих особенностей:

– EPSS предоставляет оценку вероятности эксплуатации уязвимости в течение определённого времени, выраженную в процентах от 0 до 100. Например, значение 85% означает, что вероятность использования уязвимости в ближайшем будущем составляет 85%;

– для прогнозирования вероятности эксплуатации EPSS использует разнообразные данные, включая контекст уязвимости, активность злоумышленников, публикации в открытых источниках и наличие эксплойтов. В модели также применяются алгоритмы машинного обучения для более полного анализа угроз [3-5];

– в отличие от CVSS, который фокусируется на тяжести уязвимости, EPSS фокусируется на факторах, которые указывают на её активную эксплуатацию в реальных атаках. При расчёте используются факторы, которые оказывают значительное влияние на оценку, к примеру «публичные эксплойты», «активность атакующих», «объём и частота атак» и прочие.

Одной из ключевых особенностей EPSS является то, что эта система не является заменой CVSS, а служит её дополнением. В то время как CVSS оценивает тяжесть уязвимости, предоставляя единую шкалу от 0 до 10, она не учитывает факторы, которые напрямую влияют на вероятность эксплуатации уязвимости в реальных условиях. EPSS, в свою очередь, фокусируется именно на этих факторах, что позволяет получить более точную картину риска эксплуатации.

EPSS, в отличие от CVSS, больше ориентирован на анализ реальной эксплуатации уязвимостей, что помогает специалистам по информационной

безопасности точнее определять приоритеты для устранения уязвимостей, исходя из фактической угрозы. Например, уязвимость с высокой оценкой по CVSS, но низким значением EPSS, может оказаться менее критичной для немедленного исправления, чем уязвимость с низким баллом по CVSS, но высоким значением EPSS.

OWASP Risk Rating Calculator является одним из наиболее востребованных инструментов для оценки рисков, связанных с уязвимостями веб-приложений. Основная цель калькулятора — стандартизировать процесс оценки рисков, что помогает специалистам по безопасности обоснованно приоритизировать действия по устранению уязвимостей [6].

Методология для данного инструмента состоит из четырех основных этапов:

1) определение факторов угрозы (Threat Factors);
2) оценка факторов воздействия (Impact Factors);
3) расчёт уровня риска (Risk Score Calculation);
4) классификация риска (Risk Categorization).

Факторы угрозы определяют вероятность того, что уязвимость будет успешно эксплуатирована. Параметры для факторов угрозы представлены в таблице 6.

Таблица 6 – Факторы угрозы

Фактор угрозы	Описание	Шкала оценки (1-9)
Навыки атакующего (Skill level)	Уровень знаний и умений, которые необходимы для эксплуатации уязвимости.	1 (высокий навык) — 9 (низкий навык)
Мотивированность (Motivation)	Насколько вероятно, что злоумышленники будут целенаправленно искать и эксплуатировать уязвимость.	1 (низкая) — 9 (высокая)
Доступ (Access requirements)	Уровень доступа, необходимый для эксплуатации (локальный доступ или удалённый доступ).	1 (локальный доступ) — 9 (удалённый доступ)

Последствия факторов воздействия делятся на 4 этапа, указанных в таблице 7.

Таблица 7 – Фактор воздействия

Фактор воздействия	Описание
Влияние на конфиденциальность (Confidentiality impact)	Будет ли нарушена конфиденциальность данных
Влияние на целостность (Integrity impact)	Может ли атакующий изменить данные или программное обеспечение
Влияние на доступность (Availability impact)	Могут ли пользователи потерять доступ к системе
Влияние на репутацию (Reputation impact)	Может ли эксплуатация повлиять на репутацию компании

В результате расчетов, основанных на анализе факторов угрозы и воздействия, определяется уровень риска: низкий (0-3), средний (3-6), высокий (6-9) и критический (9+).

OWASP Risk Rating Calculator представляет собой удобный инструмент для оперативной оценки рисков, особенно в контексте веб-приложений, где важно учитывать как технические, так и бизнес-аспекты угроз. Он предлагает стандартизированный подход и идеально подходит для малых и средних компаний. Однако для крупных организаций с высокими требованиями к безопасности его функционала может быть недостаточно, и в таких случаях рекомендуется использовать этот инструмент в сочетании с другими методами и инструментами оценки рисков для более детализированного анализа [7].

Сравнительный анализ риск-калькуляторов представлен в таблице 8.

Таблица 8 – Сравнительный анализ риск-калькуляторов

Критерий	CVSS	EPSS	OWASP
Цель	Оценка опасности уязвимостей	Прогноз вероятности эксплуатации	Оценка рисков для бизнеса
Методология	Шкала 0-10	Вероятность (0-100%)	Вероятность × Последствия

Продолжение таблицы 8

Критерий	CVSS	EPSS	OWASP
Фокус	Уязвимости ПО	Эксплуатация уязвимостей	Бизнес-риск приложений
Интеграция	Системы SIEM, VMS	Уязвимости и эксплойты	Pentest, аудит приложений
Возможность автоматизации	Да	Да	Нет
Основное отличие	Объективная оценка угрозы	Вероятность эксплуатации	Контекст бизнес-рисков

Несмотря на различия в функциях, CVSS, EPSS и OWASP часто используются совместно для более комплексной оценки рисков. CVSS помогает определить степень тяжести уязвимости, EPSS прогнозирует вероятность её эксплуатации, а OWASP учитывает бизнес-контекст. Такой интегрированный подход позволяет принимать более обоснованные решения, избегая излишних затрат на устранение "громких" уязвимостей, которые на практике могут не представлять значительной угрозы.

CVSS, EPSS и OWASP представляют собой три основных инструмента для оценки уязвимостей и рисков в сфере информационной безопасности. CVSS измеряет степень "опасности" уязвимостей, EPSS оценивает "вероятность их эксплуатации", а OWASP сосредоточен на "бизнес-рисках" веб-приложений. Используя их в комбинации, организации получают всестороннюю картину угроз, с которыми им предстоит столкнуться [2-3].

Совместное применение CVSS, EPSS и OWASP в рамках единого процесса управления рисками значительно усиливает защищённость и адаптивность систем безопасности.

2 Разработка моделей кибератак класса «Злоумышленник посередине»

2.1 Установление соответствия между возможными CAPEC-шаблонами атак и эксплуатируемыми ими уязвимостями

С целью повышения защиты сетевой инфраструктуры от атак «Злоумышленник посередине» будет сформирован и проанализирован набор методов, из которого исключены физические атаки на элементы безопасности, коммуникационные атаки, приёмы социальной инженерии и устаревшие шаблоны векторов CAPEC, поскольку эти виды атак не входят в область исследования.

Каталог CAPEC выступает главным справочником по распространённым схемам атак Common Attack Pattern Enumeration and Classification (CAPEC) и представляет собой открытую базу шаблонов атак. Также ресурс позволяет специалистам по кибербезопасности и конечным пользователям глубже понять приёмы эксплуатации уязвимостей, которые используют злоумышленники при проведении атак. Шаблон атаки представляет собой детальное описание методов и техник, которые злоумышленники используют для эксплуатации уязвимостей в информационных системах. Формирование такого шаблона основывается на тщательном анализе реальных инцидентов и примерах использования уязвимостей.

Каждый шаблон предоставляет информацию о построении и реализации отдельных компонентов атаки, а также включает рекомендации по минимизации её воздействия. Применение таких шаблонов помогает разработчикам и администраторам систем глубже разобраться в природе конкретных угроз и разработать более эффективные меры для их предотвращения [3].

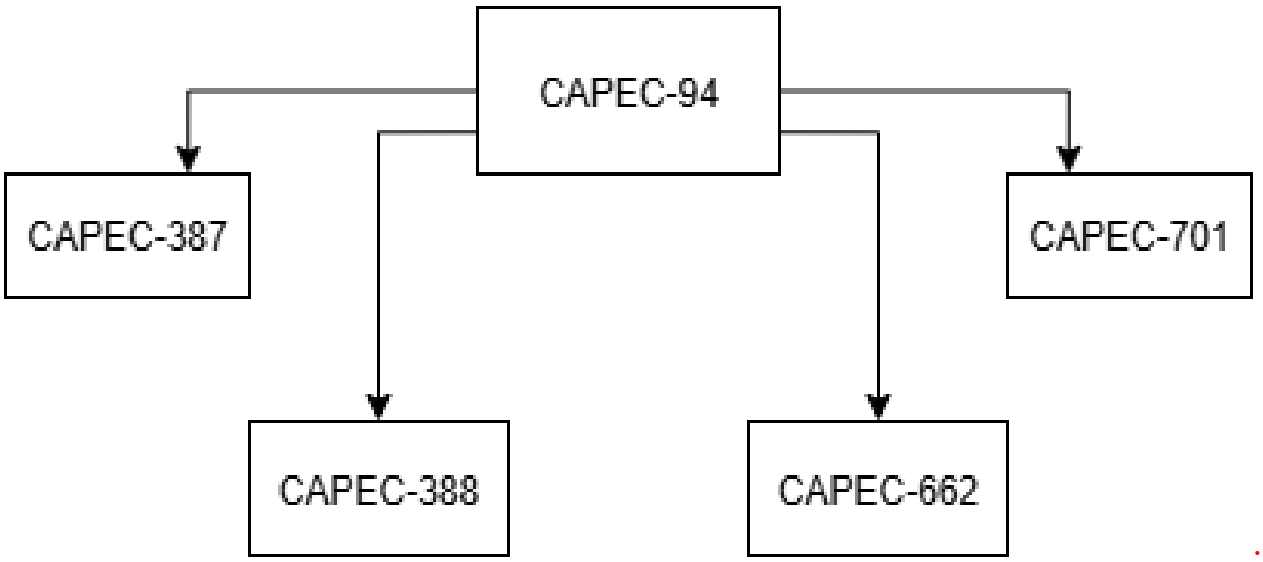


Рисунок 1 – Граф связи шаблонов CAPEC с родительским

Эта многоуровневая структура CAPEC помогает не только организовать атаки по уровням абстракции, но и четко структурировать знания об атаках, что полезно для аналитиков, разработчиков, администраторов и специалистов по кибербезопасности [2-6].

В данной работе будут рассмотрены следующие шаблоны атак:

- CAPEC-387 - Изменение навигации для распространения вредоносного контента;

- CAPEC-388 - Взлом кнопки API приложения;

- CAPEC-662 - Злоумышленник в браузере;

- CAPEC-701 - Браузер посередине.

Рассмотрим заданные шаблоны атак CAPEC более подробно.

Адаптированное описание данного класса атак выглядит следующим образом: «Злоумышленник манипулирует исходящими или входящими данными клиента в рамках приложения, чтобы изменить содержимое сообщений и тем самым обойти ожидаемую логику приложения». Паспорт вектора атаки CAPEC-387 представлен в таблице 9.

Таблица 9 – паспорт вектора атаки CAPEC-387

Идентификатор системы CAPEC	CAPEC-387 Изменение навигации для распространения вредоносного контента	
Описание вектора атаки	Злоумышленник манипулирует исходящими или входящими данными клиента в рамках приложения, чтобы изменить содержимое сообщений и тем самым обойти ожидаемую логику приложения.	
Тип атаки	Подрыв контроля доступа	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-471: Изменение предполагаемых неизменяемых данных (MAID)	Этот идентификатор CWE может использоваться для сопоставления с реальными уязвимостями
	CWE-345: Недостаточная проверка подлинности данных	Этот идентификатор CWE не следует использовать для сопоставления с реальными уязвимостями
	CWE-346: Ошибка проверки источника	Этот идентификатор CWE можно использовать для сопоставления с реальными уязвимостями в ограниченных ситуациях, требующих тщательного анализа
	CWE-602: Обеспечение безопасности на стороне клиента на стороне сервера	Этот идентификатор CWE можно использовать для сопоставления с реальными уязвимостями в ограниченных ситуациях, требующих тщательного анализа
	CAPEC-702: Использование неправильной цепочки или детализации компонентов аппаратной отладки	Этот идентификатор CWE может использоваться для сопоставления с реальными уязвимостями

Для построения графа шаблона атак будет использована база данных БДУ ФСТЭК России. Это связано с тем, что в англоязычных аналогах отсутствует информация о отечественных программных продуктах.

БДУ ФСТЭК России включает базу данных уязвимостей программного обеспечения, а также перечень и описание угроз безопасности информации, наиболее характерных для государственных информационных систем, информационных систем персональных данных и автоматизированных систем на критически важных объектах.

Используя базу данных БДУ ФСТЭК России, были выделены следующие атаки CWE и соотнесенные с ними уязвимости CVE, на основании полученных данных построим и рассмотрим древовидный граф вектора атаки CAPEC-387 представленный на рисунке 2.

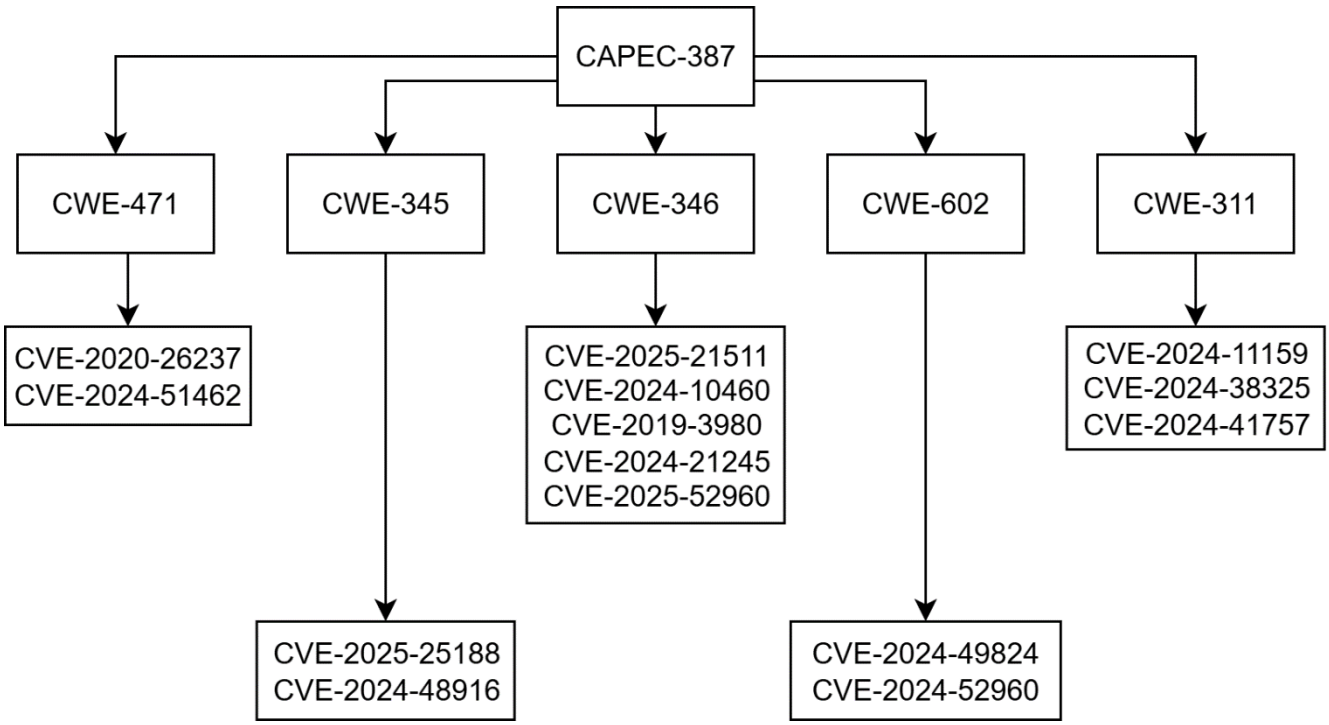


Рисунок 2 - Граф шаблона атак CAPEC-387

На основании построенного древовидного графа выделим уязвимости CAPEC-387 и составим их паспорта. Пример паспорта представлен в таблице 10. Паспорта остальных уязвимостей приведены в Приложении Б.

Таблица 10 – Паспорт уязвимости CVE-2020-26237

Идентификатор уязвимости	CVE-2020-26237 Уязвимость инструмента для подсветки синтаксиса Highlight.js связана с модификацией предполагаемых данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, нарушить целостность данных, а также вызвать отказ в обслуживании
Идентификатор типа ошибка	CWE-471
Базовый вектор уязвимости	AV:N/AC:M/Au:S/C:N/I:P/A:P
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,9)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения

CAPEC–388 – Взлом кнопки API приложения

Адаптированное описание данного класса атак выглядит следующим образом: «Злоумышленник манипулирует исходящими или входящими данными от клиента в рамках приложения, чтобы изменить место назначения и/или содержимое кнопок, отображаемых пользователю в сообщениях API. Выполнение этой атаки позволяет злоумышленнику манипулировать содержимым таким образом, чтобы создавать сообщения или содержимое, которые выглядят подлинными, но содержат кнопки, указывающие на контролируемое злоумышленником место назначения». Паспорт вектора атаки CAPEC-388 представлен в таблице 11.

Таблица 11 – Паспорт вектора атаки CAPEC-388

Идентификатор системы CAPEC	CAPEC-388 Взлом кнопки API приложения	
Описание вектора атаки	Злоумышленник манипулирует исходящими или входящими данными от клиента в рамках приложения, чтобы изменить место назначения и/или содержимое кнопок, отображаемых пользователю в сообщениях API. Выполнение этой атаки позволяет злоумышленнику манипулировать содержимым таким образом, чтобы создавать сообщения или содержимое, которые выглядят подлинными, но содержат кнопки, указывающие на контролируемое злоумышленником место назначения.	
Тип атаки	Подрыв контроля доступа	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-471: Изменение предполагаемых неизменяемых данных (MAID)	Этот идентификатор CWE может использоваться для сопоставления с реальными уязвимостями
	CWE-345: Недостаточная проверка подлинности данных	Этот идентификатор CWE не следует использовать для сопоставления с реальными уязвимостями
	CWE-346: Ошибка проверки источника	Этот идентификатор CWE можно использовать для сопоставления с реальными уязвимостями в ограниченных ситуациях, требующих тщательного анализа
	CWE-602: Обеспечение безопасности на стороне клиента на стороне сервера	Этот идентификатор CWE можно использовать для сопоставления с реальными уязвимостями в ограниченных ситуациях, требующих тщательного анализа
	CWE-311: Отсутствует шифрование конфиденциальных данных	Этот идентификатор CWE не следует использовать для сопоставления с реальными уязвимостями

Используя базу данных БДУ ФСТЭК России, были выделены следующие атаки CWE и соотнесенные с ними уязвимости CVE, на основании полученных данных построим и рассмотрим древовидный граф вектора атаки CAPEC-388 представленный на рисунке 3.

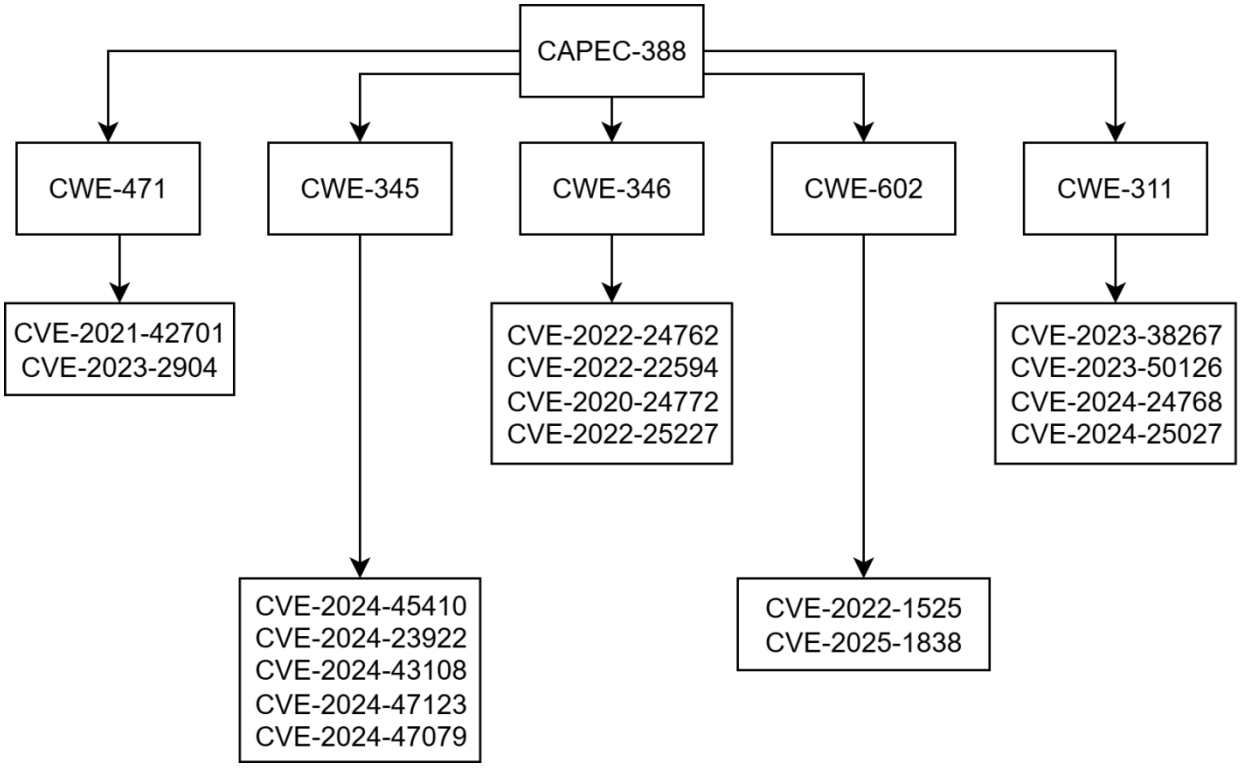


Рисунок 3 - Граф шаблона атак CAPEC-388

На основании построенного древовидного графа выделим уязвимости CAPEC-388 и составим их паспорта. Пример паспорта представлен в таблице 12, остальные – в Приложении Б.

Таблица 12 – Паспорт уязвимости CVE-2021-42701

Идентификатор уязвимости	CVE-2021-42701 Уязвимость в AzeoTech DAQFactory (в частности, версия 5.86). Злоумышленник может создать специально сформированный файл проекта, и при его открытии приложение попытается подключиться к облачному серверу, что позволит выполнить атаку «человек-посередине» (MiTM), перехватить учётные данные и получить контроль над облачной учётной записью
Идентификатор типа ошибка	CWE-471
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N

Продолжение таблицы 12

Уровень опасности уязвимости	Средний (CVSS 3.1 = 6.3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Указание на возможность MiTM-атаки и перехват учетных данных
Способ устранения	Рекомендуется установить обновления продукта AzeoTech DAQFactory как от производителя, так и патчи от ICS-CERT/US-CERT.

CAPEC-662 – Злоумышленник в браузере

Адаптированное описание данного класса атак выглядит следующим образом: «Злоумышленник использует уязвимости системы безопасности или внутренние функции веб-браузера, чтобы манипулировать трафиком между двумя конечными точками». Паспорт вектора атаки CAPEC-662 приведен в таблице 13.

Таблица 13 – паспорт вектора атаки CAPEC-662

Идентификатор системы CAPEC	CAPEC-662 Злоумышленник в браузере (AiTB)	
Описание вектора атаки	Злоумышленник использует уязвимости системы безопасности или внутренние функции веб-браузера, чтобы манипулировать трафиком между двумя конечными точками.	
Тип атаки	Подрыв контроля доступа	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-300	Этот идентификатор CWE не следует использовать для сопоставления с реальными уязвимостями
	CWE-494	Этот идентификатор CWE может использоваться для сопоставления с реальными уязвимостями

Используя базу данных БДУ ФСТЭК России, были выделены следующие атаки CWE и соотнесенные с ними уязвимости CVE. На основании полученных данных построим и рассмотрим древовидный граф вектора атаки CAPEC-662, представленный на рисунке 4.

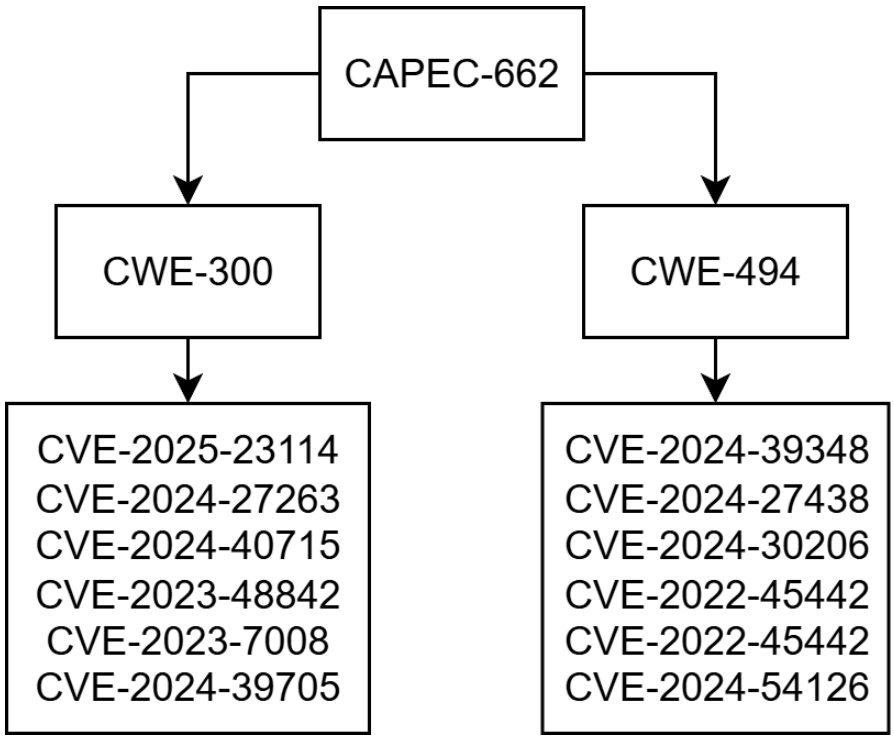


Рисунок 4 – Граф шаблона атак CAPEC – 662

На основании построенного древовидного графа выделим уязвимости CAPEC-662 и составим их паспорта (пример – в таблице 14, остальные – в Приложении Б).

Таблица 14 – Паспорт уязвимости CVE-2025-23114

Идентификатор уязвимости	CVE-2025-23114 Уязвимость загрузчика обновлений Veeam Updater средств резервного копирования и восстановления данных Veeam Backup for Salesforce, Veeam Backup for Nutanix AHV и Veeam Backup for AWS связана с доступом к каналу из точки, не являющейся конечной. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, выполнить атаку типа «человек посередине»
Идентификатор типа ошибка	CWE-300
Базовый вектор уязвимости	AV:N/AC:H/Au:N/C:C/I:C/A:C
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,6)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения

CAPEC-701 - Браузер посередине

Адаптированное описание данного класса атак выглядит следующим образом: «Злоумышленник использует внутренние функции веб-браузера, чтобы установить незаметное подключение к удаленному рабочему столу в браузере жертвы к системе злоумышленника. Злоумышленник должен развернуть веб-клиент с сеансом удаленного рабочего стола, к которому жертва может получить доступ». Паспорт вектора атаки CAPEC-701 приведен в таблице 15.

Таблица 15 – паспорт вектора атаки CAPEC-701

Идентификатор системы CAPEC	CAPEC-701: Браузер посередине	
Описание вектора атаки	Злоумышленник использует внутренние функции веб-браузера, чтобы установить незаметное подключение к удаленному рабочему столу в браузере жертвы к системе злоумышленника. Злоумышленник должен развернуть веб-клиент с сеансом удаленного рабочего стола, к которому жертва может получить доступ.	
Тип атаки	Подрыв контроля доступа	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-345: Недостаточная проверка подлинности данных	Этот идентификатор CWE не следует использовать для сопоставления с реальными уязвимостями
	CWE-294: Обход аутентификации с помощью захвата-воспроизведения	Этот идентификатор CWE может использоваться для сопоставления с реальными уязвимостями

Используя базу данных БДУ ФСТЭК России, были выделены следующие атаки CWE и соотнесенные с ними уязвимости CVE, на основании полученных данных построим и рассмотрим древовидный граф вектора атаки CAPEC-701, представленный на рисунке 5.

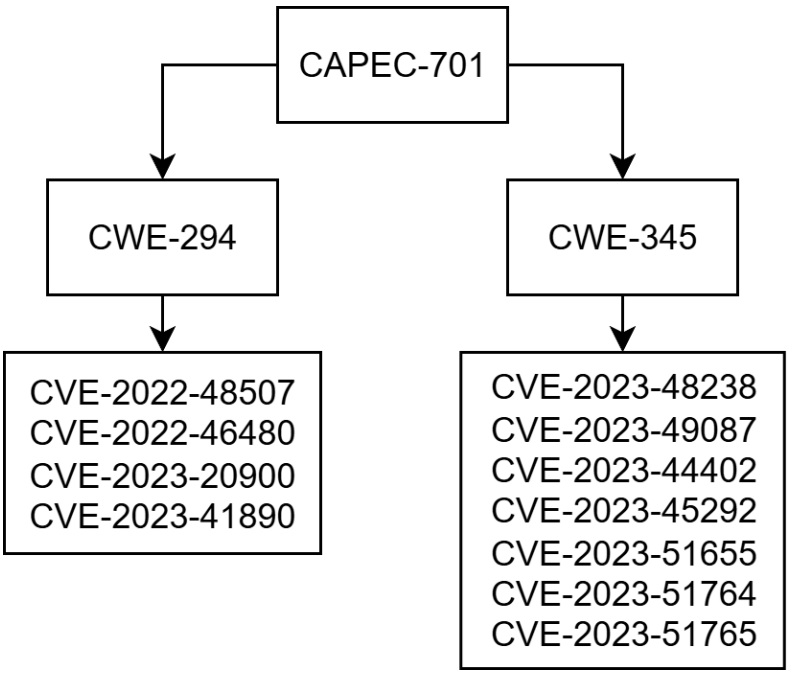


Рисунок 5 – Граф шаблона атак CAPEC-701

На основании построенного древовидного графа выделим уязвимости CAPEC-701 и составим их паспорта (пример – в таблице 16, остальные – в Приложении Б).

Таблица 16 – Паспорт уязвимости CVE-2023-20900

Идентификатор уязвимости	CVE-2023-20900 Уязвимость набора утилит VMware Tools связана с возможностью обхода подписи SAML-токена. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, повысить свои привилегии путем реализации атаки типа «человек посередине»
Идентификатор типа ошибки	CWE-294
Базовый вектор уязвимости	AV:A/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

2.2 Разработка моделей сценариев реализации шаблонов атак с использованием техник MITRE ATT&CK.

Для проведения более глубокого анализа угроз, разложим шаблоны CAPEC на эксплуатируемые тактики и техники согласно базе данных MITRE ATT&CK.

В качестве основы моделирования используются данные из базы MITRE ATT&CK: каждая техника отражает отдельный шаг действий злоумышленника. Это не только упорядочивает возможные сценарии атак, но и делает их более пригодными для практического применения. Учёт последовательных переходов в моделировании позволяет более точно отразить реальные сценарии эксплуатации уязвимостей.

В CAPEC-387 основной вектор первоначального доступа заключается в эксплуатации недостатков в общедоступных сетевых компонентах приложения. По методологии MITRE это соответствует технике T1190 – Недостатки в общедоступном приложении (тактика «Первоначальный доступ»).

Недостатки в общедоступном приложении (T1190):

1) CVE-2020-26237 – уязвимость в сетевом сервисе позволяла обходить аутентификацию и выполнять произвольный код через специально сформированные запросы;

2) CVE-2025-25188 – дыра в веб-интерфейсе портала, дающая доступ к внутренним API и возможность внедрить вредоносный JavaScript;

3) CVE-2024-48916 – ошибка в модуле обработки HTTP-запросов, позволяющая обойти фильтрацию и получить удалённый терминал.

Следующий этап – выполнение вредоносного кода в среде жертвы. Здесь задействуются две техники MITRE:

T1203 – Эксплуатация уязвимостей в клиентском ПО:

1) CVE-2025-21511 – баг в приложении, при открытии специально сформированного файла запускающий встроенный скрипт;

2) CVE-2025-24010 – уязвимость в графическом редакторе, позволяющая встраивать и выполнять посторонний код при импорте плагина.

T1059 – Интерпретаторы командной строки и сценариев:

1) CVE-2024-51462 – обход ограничений PowerShell, дающий возможность выполнять встроенные и пользовательские команды без пометки “скрипт”;

2) CVE-2024-49824 – ошибка в интерпретаторе Python, позволяющая загрузить и исполнить произвольный модуль из удалённого источника.

Для эскалации привилегий злоумышленник использует как изменение текущих учётных записей, так и прямую эксплуатацию локальных уязвимостей ОС:

T1078 – Изменение текущих учётных записей:

1) CVE-2024-38325 – позволяет сбрасывать пароли локальных пользователей без проверки прежних учётных данных;

2) CVE-2024-21245 – уязвимость в службе LDAP-аутентификации, дающая возможность добавлять себя в группу администраторов.

T1068 – Эксплуатация уязвимостей для повышения привилегий:

1) CVE-2024-52960 – переполнение буфера в драйвере ядра Windows, позволяющее выполнить произвольный код с SYSTEM-правами;

2) CVE-2024-11159 – ошибка в планировщике задач, дающая локальному пользователю право создавать задания от имени службы.

T1018 – Изучение удаленных систем:

1) CVE-2024-41757 – ошибка в SNMP-агенте, выдающая подробную информацию об установленных службах и конфигурации ОС.

После поиска других удалённых устройств по IP-адресу, имени узла или другим логическим идентификаторам в сети начинается фаза сбора информации:

T1005 – Сбор данных с локальной системы:

1) CVE-2024-10460 – уязвимость в службе обмена файлами, позволяющая массово скачивать каталоги без авторизации;

2) CVE-2019-3980 – позволяет читать конфиденциальные файлы резервных копий без дополнительных прав.

Данные о соотнесении техник и тактик с уязвимостями для шаблона атаки CAPEC-387 сведены в таблицу 17.

Таблица 17 – Соотнесение техник и тактик с уязвимостями для шаблона атаки CAPEC-387

Тактика	Техника	Уязвимости, эксплуатируемые соответствующей техникой
Первоначальный доступ	T1190 – Недостатки в общедоступном приложении	CVE-2020-26237
		CVE-2025-25188
		CVE-2024-48916
Выполнение	T1203 – Эксплуатация уязвимостей в клиентском ПО	CVE-2025-21511
		CVE-2025-24010
	T1059 – Интерпретаторы командной строки и сценариев	CVE-2024-51462
		CVE-2024-49824
Повышение привилегий	T1078 - Изменение текущих учётных записей	CVE-2024-38325
		CVE-2024-21245
	T1068 – Эксплуатация уязвимостей для повышения привилегий	CVE-2024-52960
		CVE-2024-11159
Обнаружение	T1018 - Изучение удаленных систем	CVE-2024-41757
Сбор	T1005 - Эксплуатация с локальной системы	CVE-2019-3980
		CVE-2024-10460

В CAPEC-388 началом атаки является активное сканирование сетевых сервисов и приложений с целью выявления уязвимых компонентов. По методологии MITRE это соответствует технике T1595 (Активное сканирование) внутри тактики «Разведка».

Активное сканирование (T1595):

1) CVE-2022-1525 – уязвимость в модуле анализа сетевых пакетов, позволяла обходить фильтры и собирать подробную информацию о службах без детектирования;

2) CVE-2025-1838 – баг в библиотеке обнаружения сервисов, позволяющий отправлять специально сформированные запросы для индикации открытых портов.

На этапе «Первоначальный доступ» злоумышленники эксплуатируют недостатки в общедоступных приложениях, что по MITRE соответствует технике T1190 (Недостатки в общедоступном приложении).

Недостатки в общедоступном приложении (T1190):

1) CVE-2021-42701 – уязвимость в веб-сервере, позволяющая удалённо выполнить произвольный код через специально сформированный HTTP-запрос;

2) CVE-2023-2904 – ошибка в API публичного портала, обходящая аутентификацию;

3) CVE-2024-45410 – уязвимость в мобильном интерфейсе приложения, раскрывающая административные функции;

4) CVE-2024-43108 – XSS-уязвимость в панели управления, позволяющая захватить сессионные токены.

Дальнейшая стадия «Выполнение» демонстрирует запуск вредоносного кода через две техники:

Интерпретаторы командной строки и сценариев (T1059):

1) CVE-2024-47123 – баг в интерпретаторе Bash, позволяющий выполнить произвольные команды из удалённо подгруженного скрипта.

Исполнение с участием пользователя (T1204):

1) CVE-2024-47079 – уязвимость в клиентском приложении, требующая от пользователя открыть вредоносный файл, после чего происходит запуск встроенного кода.

Для повышения привилегий происходит эксплуатация локальных уязвимостей по технике T1068 (Эксплуатация уязвимостей для повышения привилегий).

Эксплуатация уязвимостей для повышения привилегий (T1068):

1) CVE-2023-38267 – переполнение буфера в драйвере ядра Windows, позволяющее получить системные привилегии;

2) CVE-2023-50126 – ошибка в подсистеме контроля доступа NTFS, обходимая локально;

3) CVE-2024-24768 – уязвимость в менеджере учётных записей, позволяющая подделать токены безопасности;

4) CVE-2024-25027 – баг в ядре Linux, дающий возможность эскалации до прав root.

Для перемещения внутри периметра применяются как эксплоиты служб удалённого доступа, так и удалённых сервисов:

Эксплуатация службы удалённого доступа (T1021):

1) CVE-2022-22594 – критическая уязвимость в RDP, позволяющая произвольно подключаться без корректной аутентификации;

2) CVE-2020-24772 – баг в SSH-агенте, раскрывающий ключи при определённых условиях.

Эксплуатация уязвимостей в удалённых службах (T1210):

1) CVE-2024-23922 – ошибка в службе обмена сообщениями, дающая возможность удалённого исполнения кода.

В финальной фазе «Сбор данных» злоумышленник использует технику T1005 (Эксплуатация с локальной системы).

Эксплуатация с локальной системы (T1005):

1) CVE-2022-24762 – уязвимость в локальной утилите сбора логов, позволяющая извлекать и передавать конфиденциальные файлы без ограничения доступа.

Данные о соотнесении техник и тактик с уязвимостями для шаблона атаки CAPEC-388 сведены в таблицу 18.

Таблица 18 – Соотнесение техник и тактик с уязвимостями для шаблона атаки CAPEC-388

Тактика	Техника	Уязвимости, эксплуатируемые соответствующей техникой
Разведка	T1595 - Активное сканирование	CVE-2022-1525
		CVE-2025-1838
Первоначальный доступ	T1190 - Недостатки в общедоступном приложении	CVE-2021-42701
		CVE-2023-2904
		CVE-2024-45410
		CVE-2024-43108
Исполнение	T1059 - Интерпретаторы командной строки и сценариев	CVE-2024-47123
	T1204 - Выполнение с участием пользователя	CVE-2024-47079
Повышение привилегий	T1068 – Эксплуатация уязвимостей для повышения привилегий	CVE-2023-38267
		CVE-2023-50126
		CVE-2024-24768
		CVE-2024-25027
Перемещение внутри периметра	T1021 - Эксплуатация службы удаленного доступа	CVE-2022-22594
		CVE-2020-24772
	T1210 - Эксплуатация уязвимостей в удаленных службах	CVE-2024-23922
Сбор	T1005 - Эксплуатация с локальной системы	CVE-2022-24762

В CAPEC-662 ключевым способом начала атаки является эксплуатация уязвимостей в публично-доступных приложениях и компрометация цепочек поставок, что по методологии MITRE соответствует техникам T1190 и T1195.003 внутри тактики «Первоначальный доступ».

Недостатки в публичном приложении и цепочке поставок:

1) CVE-2024-40715 – уязвимость в веб-интерфейсе публичного сервиса позволяла удалённо выполнить произвольный код без аутентификации;

2) CVE-2024-30206 – баг в компоненте стороннего поставщика приводил к раскрытию конфиденциальных данных при загрузке обновлений.

Дальнейшая стадия выполнения кода (тактика «Выполнение») демонстрируется через эксплуатацию уязвимостей в клиентских приложениях и привлечение пользователя к запуску вредоносного кода.

Эксплуатация уязвимостей в клиентском ПО (T1203):

1) CVE-2025-23114 – уязвимость в процессе сборки ПО, позволяющая подменить библиотеку на вредоносную при сборке дистрибутива.

2) CVE-2024-39705 – ошибка в обработке документов офисного пакета, дающая возможность запускать произвольные скрипты при открытии файла;

3) CVE-2024-39348 – уязвимость в плагине мультимедиа для браузера, позволяющая выполнить код через специально сформированный поток;

4) CVE-2024-27438 – баг в библиотеке отображения графики, приводящий к переполнению буфера и удалённому исполнению шелл-команд.

Выполнение с участием пользователя (T1204):

1) CVE-2022-45442 – социально-инженерная атака через фишинговое сообщение, побуждающее пользователя вручную запустить вредоносный исполняемый файл.

Для закрепления присутствия (тактика «Закрепление») злоумышленник загружает в систему сторонние DLL-библиотеки (T1574.002):

1) CVE-2024-27263 – уязвимость в модуле расширений позволяет загрузить и зарегистрировать вредоносную DLL, которая автоматически подгружается при старте сервисов.

Получение учётных данных достигается при помощи техники «Злоумышленник-посредник» (T1557):

1) CVE-2023-47742 – MITM-атака на сетевом канале передачи файла, перехватывающая и модифицирующая данные;

2) CVE-2023-7008 – уязвимость в прокси-решении, позволяющая раскрыть хэшированные пароли при аутентификации клиента.

В финальной деструктивной фазе (тактика «Воздействие») злоумышленник повреждает прошивку устройств (T1495):

1) CVE-2024-54126 – ошибка в механизме обновления микроконтроллера позволяет записать некорректный образ, приводящий к безвозвратной потере функциональности.

Данные о соотнесении техник и тактик с уязвимостями для шаблона атаки CAPEC-662 сведены в таблицу 19.

Таблица 19 – Соответствие параметров вероятных сценариев реализации кибератаки шаблона CAPEC – 662

Тактика	Техника	Уязвимости, эксплуатируемые соответствующей техникой
Первоначальный доступ	T1190 - Эксплуатация публичного приложения	CVE-2024-40715
	T1195.003 - Компрометация цепочки поставок комплектующих	CVE-2024-30206
Выполнение	T1203 - Эксплуатация уязвимостей в клиентском ПО	CVE-2025-23114
		CVE-2024-39705
		CVE-2024-39348
		CVE-2024-27438
	T1204 - Выполнение с участием пользователя	CVE-2022-45442
Закрепление	T1574.002 - Загрузка сторонних DLL-библиотек	CVE-2024-27263
Получение учетных данных	T1557 - "Злоумышленник посередине"	CVE-2023-47742
		CVE-2023-7008
Деструктивное воздействие	T1495 - Повреждение прошивки	CVE-2024-54126

В CAPEC-701 ключевым способом начала атаки является эксплуатация уязвимостей в общедоступных приложениях (T1190) и уязвимостей в клиентском

программном обеспечении (T1203), что по методологии MITRE соответствует техникам внутри тактики «Первоначальный доступ».

Недостатки в общедоступном приложении (T1190):

1) CVE-2022-48507 – уязвимость обхода проверки подлинности в модуле хранилища, позволяющая получить несанкционированный доступ к данным

2) CVE-2023-20900 – ошибка в веб-портале администрирования, приводящая к удалённому выполнению произвольного кода при некорректных правах доступа.

Эксплуатация уязвимостей в клиентском ПО (T1203):

1) CVE-2023-45292 – баг в почтовом клиенте, позволяющий запускать вредоносные скрипты при открытии вложений.

Дальнейшая стадия достижения выполнения кода ложится на техники внутри тактики «Выполнение».

Интерпретаторы командной строки и сценариев (T1059):

1) CVE-2022-46480 – уязвимость в PowerShell, позволяющая обойти политики выполнения скриптов;

Эксплуатация компонентов серверного ПО (T1505):

1) CVE-2023-41890 – ошибка в серверном модуле базы данных, открывающая возможность выполнения произвольных SQL-команд;

2) CVE-2023-44402 – дыра в веб-фреймворке, приводящая к удалённому исполнению кода на стороне сервера.

Для повышения привилегий злоумышленник применяет технику эксплуатации локальных уязвимостей ядра (T1068) в рамках тактики «Повышение привилегий»:

1) CVE-2023-51655 – переполнение буфера в драйвере сетевого адаптера, позволяющее выполнить код в контексте ядра;

2) CVE-2023-51764 – ошибка проверки прав доступа в подсистеме управления памятью;

3) CVE-2023-51765 – уязвимость в модуле контроля привилегий, позволяющая повысить уровень доступа до системного.

Чтобы скрыть своё присутствие и затруднить обнаружение, атакующий использует технику эксплуатации удалённых служб доступа (T1021) — тактика «Предотвращение обнаружения»:

1) CVE-2023-48238 – уязвимость в службе удалённого рабочего стола, обходящая аутентификацию и шифрование.

Наконец, для перемещения внутри сети по тактике «Перемещение внутри периметра» применяется перехват сессии браузера (T1185):

1) CVE-2023-49087 – атака на cookie-хранилище браузера, позволяющая похитить сеансовые токены и выдать себя за легитимного пользователя.

Данные о соотнесении техник и тактик с уязвимостями для шаблона атаки CAPEC-701 сведены в таблицу 20.

Таблица 20 - Соотнесение техник и тактик с уязвимостями для шаблона атаки CAPEC-701

Тактика	Техника	Уязвимости, эксплуатируемые соответствующей техникой
Первоначальный доступ	T1190 - Недостатки в общедоступном приложении	CVE-2022-48507
		CVE-2023-20900
	T1203 - Эксплуатация уязвимостей в клиентском ПО	CVE-2023-45292
Исполнение	T1059 - Интерпретаторы командной строки и сценариев	CVE-2022-46480
	T1505 – эксплуатация компонентов серверного ПО	CVE-2023-41890
Повышение привилегий	T1068 - Эксплуатация уязвимостей для повышения привилегий	CVE-2023-44402
		CVE-2023-51655
		CVE-2023-51764
		CVE-2023-51765
Предотвращение обнаружения	T1021 - Эксплуатация службы удаленного доступа	CVE-2023-48238
Перемещение внутри периметра	T1185 - Перехват сессии браузера	CVE-2023-49087

3 Оценка рисков успешной реализации атак класса «Злоумышленник посередине»

3.1 Оценка критичности эксплуатируемых уязвимостей

В данном разделе осуществляется комплексная оценка критичности уязвимостей, эксплуатируемых в рамках выделенных шаблонов MitM-атаки.

Для этого на первом этапе проведем расчет критичности уязвимостей с помощью используемых в настоящее время риск-калькуляторов – CVSS 3.x, CVSS 4.0, EPSS и OWASP Risk Rating, что позволит получить оценки каждой из уязвимостей согласно используемым ими методикам (табл. 21 – 24):

Таблица 21 – Оценка уязвимостей с помощью риск-калькуляторов для CAPEC – 387

Идентификатор уязвимости	Оценка CVSS 3.x	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2020-26237	6,6	6,8	0,166	3,75
CVE-2025-25188	6,5	5,7	0,1	3,125
CVE-2024-48916	8,1	8,6	0,2545	4,625
CVE-2025-21511	7,5	8,7	0,4	5,625
CVE-2025-24010	6,5	6,8	0,353	3,75
CVE-2024-51462	4	5,1	0,25	3,125
CVE-2024-49824	6,5	7,1	0,44	3,25
CVE-2024-38325	5,9	6,2	0,17	3,5
CVE-2024-21245	5,4	5,9	0,35	4,375
CVE-2024-52960	4,3	5,3	0,36	4,625
CVE-2024-11159	5,3	6	0,45	3,875
CVE-2024-41757	5,9	6,2	0,19	4,75
CVE-2019-3980	9,8	9,3	0,29089	6,125
CVE-2024-10460	5,3	6,9	0,65	3,875

Таблица 22 – Оценка уязвимостей с помощью риск-калькуляторов для CAPEC – 388

Идентификатор уязвимости	Оценка CVSS 3.x	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2022-1525	9,8	9,3	0,31	5,125
CVE-2025-1838	6,5	7,1	0,67	5,875
CVE-2021-42701	7,5	8,1	0,11	4,125
CVE-2023-2904	7,1	7,9	0,124	3,875
CVE-2024-45410	9,8	9,3	0,4631	5,875
CVE-2024-43108	6,5	7,1	0,11	4,125
CVE-2024-47123	5,3	6	0,12	4,625
CVE-2024-47079	6,4	6,1	0,17	4,875
CVE-2023-38267	5,5	6,8	0,24	3,25

Продолжение таблицы 22

Идентификатор уязвимости	Оценка CVSS 3.x	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2023-50126	6,5	7,1	0,4	5
CVE-2024-24768	7,5	8,7	0,48	3,625
CVE-2024-25027	5,5	6,8	0,15	3,75
CVE-2022-22594	7,5	8,7	0,1	5,375
CVE-2020-24772	8,8	9,2	0,114	4,125
CVE-2024-23922	6,8	7	0,124	4,125
CVE-2022-24762	6,5	6,9	0,187	3

Таблица 23 – Оценка уязвимостей с помощью риск-калькуляторов для CAPEC – 662

Идентификатор уязвимости	Оценка CVSS 3.x	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2024-40715	7,7	8,2	0,125	4,375
CVE-2024-30206	8,8	8,7	0,1017	5,125
CVE-2025-23114	9	9,5	0,8	5,75
CVE-2024-39705	9,8	9,3	0,1484	5
CVE-2024-39348	7,5	7,9	0,109	4,125
CVE-2024-27438	7,5	7,2	0,2566	3,625
CVE-2022-45442	8,8	9,5	0,142	5,5
CVE-2024-27263	5,3	6	0,21	4,5
CVE-2023-47742	5,9	7,2	0,33	5
CVE-2023-7008	5,9	7,2	0,295	3,75
CVE-2024-54126	6,8	8,5	0,15	4,125

Таблица 24 – Оценка уязвимостей с помощью риск-калькуляторов для CAPEC – 701

Идентификатор уязвимости	Оценка CVSS 3.x	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2022-48507	7,5	8,2	0,48	4,5
CVE-2023-20900	7,5	7,7	0,953	3,125
CVE-2023-45292	5,3	6,9	0,71	3,875
CVE-2022-46480	8,1	8,6	0,8	4,875
CVE-2023-41890	7,5	8,7	0,135	4,75
CVE-2023-44402	8,6	9,2	0,37	5
CVE-2023-51655	9,8	9,3	0,37	5,5
CVE-2023-51764	7,4	6,9	0,21846	3,25
CVE-2023-51765	5,3	6,9	0,11	3,125
CVE-2023-48238	7,5	8,7	0,136	6,5
CVE-2023-49087	7,5	8,6	0,205	4,75

Важным шагом на данном этапе является формализация исходных метрик, полученных с помощью используемых риск-калькуляторов (CVSS 3.1, CVSS 4.0, EPSS и OWASP Risk Rating). Учитывая, что каждый из использованных риск-калькуляторов оперирует собственным диапазоном значений и набором факторов,

полученные с их помощью оценки критичности уязвимостей приведем к общей нормированной шкале, что позволит использовать полученные нормализованные оценки в дальнейших расчётах. Найдём нормализованные оценки критичности уязвимостей по формуле (1):

$$S_{norm} = \frac{S - S_{min}}{S_{max} - S_{min}}, \quad (1)$$

где S_{min} и S_{max} – минимальное и максимальное возможные значения шкалы S. Для имеющихся значений калькуляторов CVSS 3.x, CVSS 4.0 и OWASP имеем $S_{min} = 0$, $S_{max} = 10$. Значения EPSS находятся в пределах $S_{min} = 0$, $S_{max} = 1$, это означает, что шкала уже нормализована.

Затем для каждой уязвимости рассчитаем среднее значение нормализованных показателей. Формула для его нахождения выглядит следующим образом:

$$\bar{S} = \frac{1}{4}(S_{norm,\,1} + S_{norm,\,2} + S_{norm,\,3} + S_{norm,\,4}), \quad (2)$$

где $S_{norm,i}$ – нормализованные оценки критичности соответствующих порядку представления в таблице калькуляторов, посчитанные по формуле (1).

Для более гибкого учёта разброса оценок, введём дополнительные метрики. Стандартное отклонение нормализованных оценок найдём по формуле (3):

$$\sigma = \sqrt{\frac{1}{3}\left(\left(S_{norm,\,1} - \bar{S}\right)^2 + \left(S_{norm,\,2} - \bar{S}\right)^2 + \left(S_{norm,\,3} - \bar{S}\right)^2 + \left(S_{norm,\,4} - \bar{S}\right)^2\right)} \quad (3)$$

где делитель равен 3, так как при оценке дисперсии число степеней свободы считается равной: $m - 1$, где m – число калькуляторов.

Примеры расчета нормализованных оценок (1), их среднего значения (2) и стандартного отклонения (3) для нескольких уязвимостей шаблона CAPEC-662 представлены в таблице 25.

Таблица 25 – Нормализованные оценки, среднее значение и стандартное отклонение нормализованных оценок для уязвимостей

CVE	$S_{norm,1}$	$S_{norm,2}$	$S_{norm,3}$	$S_{norm,4}$	$\bar{S}$	σ
CVE-2024-40715	0,77	0,82	0,10301	0,4375	0,5326275	0,332940983
CVE-2024-30206	0,88	0,87	0,13694	0,5125	0,59986	0,352789236
CVE-2025-23114	0,9	0,95	0,1	0,575	0,63125	0,391245341
CVE-2024-39705	0,98	0,93	0,724	0,5	0,7835	0,219079133
CVE-2024-39348	0,75	0,79	0,4321	0,4125	0,59615	0,201566672
CVE-2024-27438	0,75	0,72	0,14	0,3625	0,493125	0,293948514
CVE-2022-45442	0,88	0,95	0,38	0,55	0,69	0,270431754
CVE-2024-27263	0,53	0,6	0,682	0,45	0,5655	0,098932637

Значимость (вес) калькуляторов определяет, насколько вклад каждого отдельного риск-калькулятора в итоговой оценке критичности отличается от средней, и тем самым решает, какие оценки заслуживают большего внимания. Найдем вес по формуле (4) и представим в таблице 26:

$$w_i = \frac{S_{norm,i}}{\sigma}. \quad (4)$$

Таблица 26 – Расчёт веса калькуляторов для уязвимостей

CVE	w_1	w_2	w_3	w_4
CVE-2024-40715	2,312722	2,462899	0,309394	1,314047
CVE-2024-30206	2,494407	2,466062	0,388164	1,452709
CVE-2025-23114	2,300347	2,428144	0,255594	1,469666
CVE-2024-39705	4,473269	4,245041	3,304742	2,28228
CVE-2024-39348	3,720853	3,919299	2,143708	2,046469
CVE-2024-27438	2,551467	2,449409	0,476274	1,233209
CVE-2022-45442	3,254056	3,512901	1,40516	2,033785
CVE-2024-27263	5,357181	6,064733	6,89358	4,54855

Чтобы сумма весов давала единицу, и мы могли бы применять их как коэффициенты при взвешивании, необходимо провести нормализацию по формуле (5).

$$w_{norm,i} = \frac{w_i}{\sum_{i=1}^{n} w_i}, \quad (5)$$

где n – это количество калькуляторов.

Нормализованные веса значений риск-калькуляторов для нескольких уязвимостей представим в таблице 27.

Таблица 27 – Нормализованные веса калькуляторов

CVE	$w_{norm,1}$	$w_{norm,2}$	$w_{norm,3}$	$w_{norm,4}$
CVE-2024-40715	0,361416	0,384884	0,04835	0,20535
CVE-2024-30206	0,366752	0,362585	0,175829	0,213592
CVE-2025-23114	0,356436	0,376238	0,122782	0,227723
CVE-2024-39705	0,312699	0,296745	0,560152	0,159541
CVE-2024-39348	0,314518	0,331292	0,475883	0,172985
CVE-2024-27438	0,380228	0,365019	0,227914	0,183777
CVE-2022-45442	0,318841	0,344203	0,373933	0,199275
CVE-2024-27263	0,234306	0,265252	0,590384	0,198939

Каждую нормированную оценку умножаем на соответствующий нормированный вес согласно формуле (6) и представляем взвешенные нормированные оценки в таблице 28:

$$S_{weighted} = S_{norm} * w_{norm,i}. \quad (6)$$

Таблица 28 – Взвешенные нормированные оценки уязвимостей

CVE	$S_{weighted,1}$	$S_{weighted,2}$	$S_{weighted,3}$	$S_{weighted,4}$
CVE-2024-40715	0,27829	0,315605	0,004981	0,089841
CVE-2024-30206	0,322742	0,315449	0,024078	0,109466
CVE-2025-23114	0,320792	0,357426	0,012278	0,130941
CVE-2024-39705	0,306445	0,275973	0,40555	0,07977
CVE-2024-39348	0,235889	0,261721	0,205629	0,071356
CVE-2024-27438	0,285171	0,262814	0,031908	0,066619
CVE-2022-45442	0,28058	0,326993	0,142095	0,109601
CVE-2024-27263	0,124182	0,159151	0,402642	0,089523

После расчёта взвешенной оценки для каждого критерия i, получим итоговую средневзвешенную оценку по формуле (7):

$$S_{final} = S_{weighted,1} + S_{weighted,2} + S_{weighted,3} + S_{weighted,4}. \quad (7)$$

Альтернативный подход для расчёта критичности данных уязвимостей – это использование среднеквадратичной оценки, что можно рассчитать по формуле (8):

$$S_{final} = \sqrt{\frac{1}{n}} \sum_{i=1}^{n} s_{norm,i}^2. \quad (8)$$

Для дальнейших расчётов будет использоваться среднеквадратичная оценка. В отличие от средневзвешенного коэффициента, из-за возведения нормированных значений в квадрат усиливается влияние критических оценок. Это позволит без усреднения, отражать важность критических данных в контексте оценки каждого калькулятора. Проведём подсчёты значений критичности по показанным формулам для всех уязвимостей рассматриваемых шаблонов атаки в таблицах 29 – 32.

Таблица 29 – Расчёт критичности уязвимостей CAPEC-387

Идентификатор уязвимости	Значение критичности
CVE-2020-26237	0,512061
CVE-2025-25188	0,46268
CVE-2024-48916	0,638947
CVE-2025-21511	0,643194
CVE-2025-24010	0,710201
CVE-2024-51462	0,375366
CVE-2024-49824	0,635054
CVE-2024-38325	0,492595
CVE-2024-21245	0,467539
CVE-2024-52960	0,564391
CVE-2024-11159	0,521109
CVE-2024-41757	0,494186
CVE-2019-3980	0,746063
CVE-2024-10460	0,59608

Таблица 30 – Расчёт критичности уязвимостей для CAPEC-388

Идентификатор уязвимости	Значение критичности
CVE-2022-1525	0,750601
CVE-2025-1838	0,594376
CVE-2021-42701	0,742848
CVE-2023-2904	0,587664
CVE-2024-45410	0,738452
CVE-2024-43108	0,552211

Продолжение таблицы 30

Идентификатор уязвимости	Значение критичности
CVE-2024-47123	0,582861
CVE-2024-47079	0,517972
CVE-2023-38267	0,502929
CVE-2023-50126	0,57304
CVE-2024-24768	0,608861
CVE-2024-25027	0,481287
CVE-2022-22594	0,639248
CVE-2020-24772	0,809175
CVE-2024-23922	0,532811
CVE-2022-24762	0,503001

Таблица 31 – Расчёт критичности уязвимостей для CAPEC-662

Идентификатор уязвимости	Значение критичности
CVE-2024-40715	0,605664
CVE-2024-30206	0,673184
CVE-2025-23114	0,716436
CVE-2024-39705	0,806145
CVE-2024-39348	0,621182
CVE-2024-27438	0,554956
CVE-2022-45442	0,728663
CVE-2024-27263	0,571954
CVE-2023-47742	0,529174
CVE-2023-7008	0,51885
CVE-2024-54126	0,694827

Таблица 32 – Расчёт критичности уязвимостей для CAPEC-701

Идентификатор уязвимости	Значение критичности
CVE-2022-48507	0,645717
CVE-2023-20900	0,735062
CVE-2023-45292	0,593982
CVE-2022-46480	0,753883
CVE-2023-41890	0,62515
CVE-2023-44402	0,7023
CVE-2023-51655	0,752446
CVE-2023-51764	0,54246
CVE-2023-51765	0,465499
CVE-2023-48238	0,6634
CVE-2023-49087	0,626448

3.2 Расчёт рисков реализации сценариев атак

Для дальнейшего расчёта рисков, связанных с единичными атаками, следует сначала определить значение ущерба, учитывающее различные свойства информации. Используем следующую формулу:

$$U = 1 - (1 - U_{к})(1 - U_{д})(1 - U_{ц}), \quad (9)$$

где $U_{к}$, $U_{д}$, $U_{ц}$ – коэффициенты, характеризующие ущерб конфиденциальности, доступности и целостности, соответственно.

Вероятность эксплуатации уязвимостей соответствующей техникой посчитаем по формуле (10):

$$P_{ij} = \frac{K_{ij}}{\sum_{z=1}^{m} K_{iz}}, \quad (10)$$

где K_{ij} – это значение критичности уязвимости j, эксплуатируемой техникой i; m – количество уязвимостей, эксплуатируемых техникой i.

Сформируем сводную таблицу данных, для шаблона CAPEC-387. Техники эксплуатации уязвимостей и их критичности возьмем из таблиц 17 и 29 соответственно. Также посчитаем сопутствующий ущерб уязвимостей и вероятности успешной эксплуатации по формулам (9) и (10). Представим это в таблице 33.

Таблица 33 – Соответствие параметров вероятных сценариев реализации кибератаки шаблона CAPEC-387

Шаблон атаки	Техники	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей	Вероятности успешной эксплуатации уязвимостей	Ущерб
CAPEC-387	T1190	CVE-2020-26237	0,512061	0,32	0,2
		CVE-2025-25188	0,46268	0,29	0,2
		CVE-2024-48916	0,638947	0,39	0,2
		CVE-2024-51462	0,643194	0,48	0,2

Продолжение таблицы 33

Шаблон атаки	Техники	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей	Вероятности успешной эксплуатации уязвимостей	Ущерб
CAPEC-387	T1059	CVE-2024-51462	0,643194	0,48	0,2
		CVE-2024-49824	0,710201	0,52	0,2
		ИЛИ			
	T1203	CVE-2025-21511	0,375366	0,37	0,2
		CVE-2025-24010	0,635054	0,63	0,2
	T1078	CVE-2024-38325	0,492595	0,51	0,5
		CVE-2024-21245	0,467539	0,49	0,2
		ИЛИ			
	T1068	CVE-2024-52960	0,564391	0,52	0,2
		CVE-2024-11159	0,521109	0,48	0,5
	T1018	CVE-2024-41757	0,494186	1	0,5
	T1005	CVE-2024-10460	0,746063	0,56	0,6
		CVE-2019-3980	0,59608	0,44	0,2

Визуализируем таблицу в виде графа атак с указанием вероятностей успешного использования дыр системы на рисунке 6:

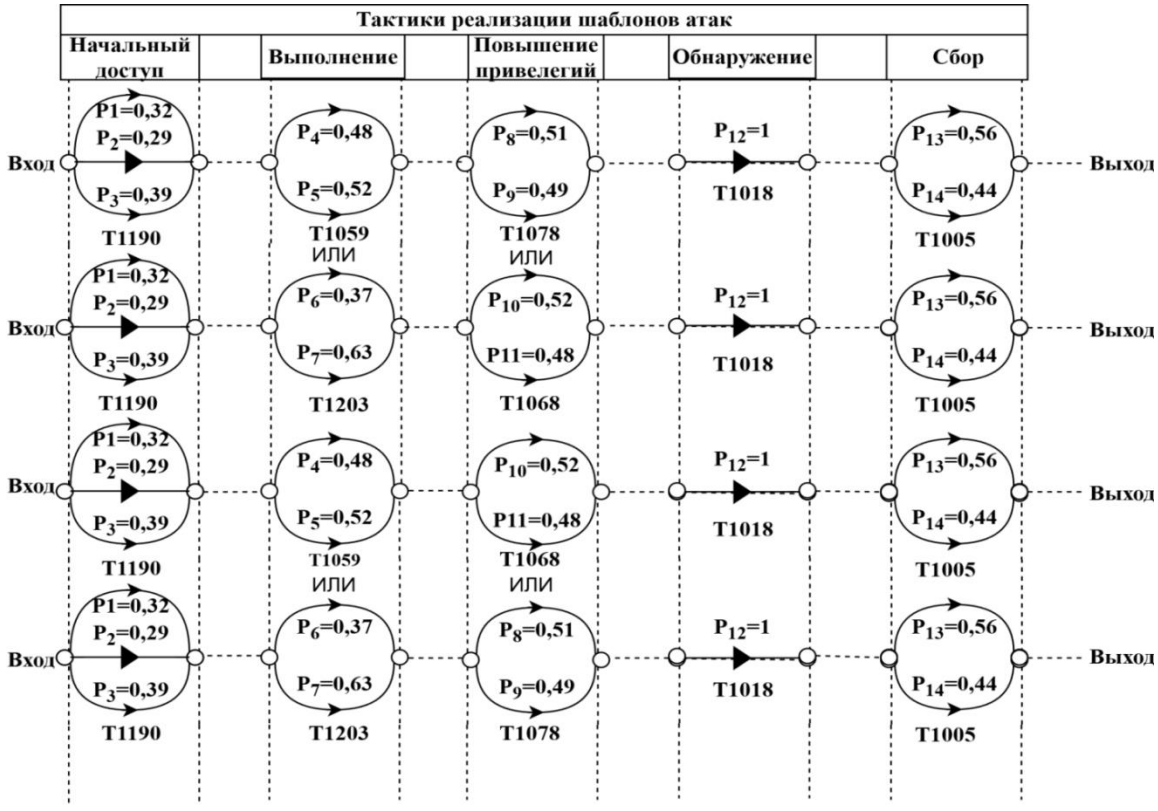


Рисунок 6 – Графовая модель вероятных сценариев реализации шаблона CAPEC-387

P_i – Вероятность успешной эксплуатации уязвимости.
Номера индексов соответствуют следующим уязвимостям:
1 - CVE-2020-26237; 2 - CVE-2025-25188; 3 - CVE-2024-48916;
4 - CVE-2024-51462; 5 - CVE-2024-49824; 6 - CVE-2025-21511;
7 - CVE-2025-24010; 8 - CVE-2024-38325; 9 - CVE-2024-21245;
10 - CVE-2024-52960; 11 - CVE-2024-11159; 12 - CVE-2024-41757;
13 - CVE-2024-10460; 14 - CVE-2019-3980.

Используя формулу (11), можно произвести оценку риска [*], возникающего при реализации избранного сценария шаблона CAPEC:

$$Risk_{\sum} = \prod_{i=1}^{k} P_i \times \sum_{j=1}^{k} U_j, \tag{11}$$

где P_i – вероятность эксплуатации i-ой уязвимости посредством реализации техники; U_j – ущерб, наносимый атакуемой системе в результате эксплуатации уязвимости в ходе реализации техники; k – количество используемых техник [*].

Согласно рисунку 6, имеем 240 возможных сценариев. Используя формулу (11) для каждого варианта, найдём экстремумы – с наибольшей и наименьшей оценкой риска:

$$Risk_{max} = (0{,}39 * 0{,}63 * 0{,}51 * 1 * 0{,}56) * (0{,}2 + 0{,}2 + 0{,}5 + 0{,}5 + 0{,}6) = 0{,}1403;$$
$$Risk_{min} = (0{,}29 * 0{,}37 * 0{,}51 * 1 * 0{,}44) * (0{,}2 + 0{,}2 + 0{,}5 + 0{,}5 + 0{,}2) = 0.0385.$$

Сценарий, с наибольшей оценкой риска, представим на рисунке 7, а наименьшей на рисунке 8.

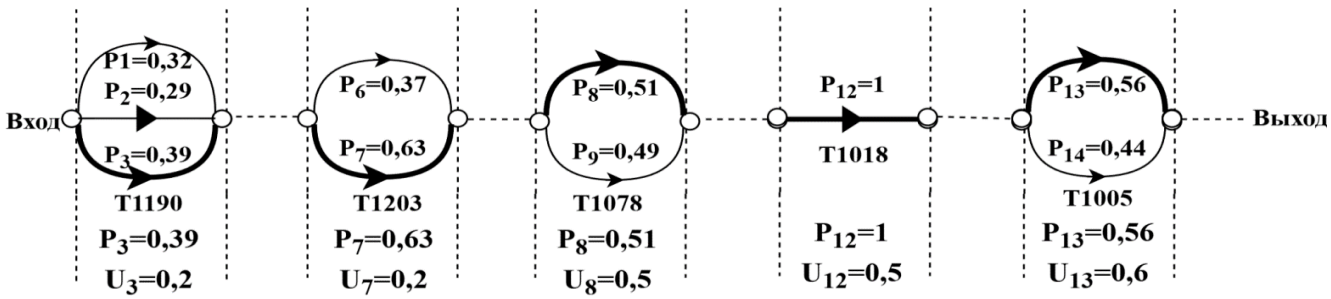


Рисунок 7 – Сценарий атаки шаблона CAPEC-387 с наибольшей оценкой риска

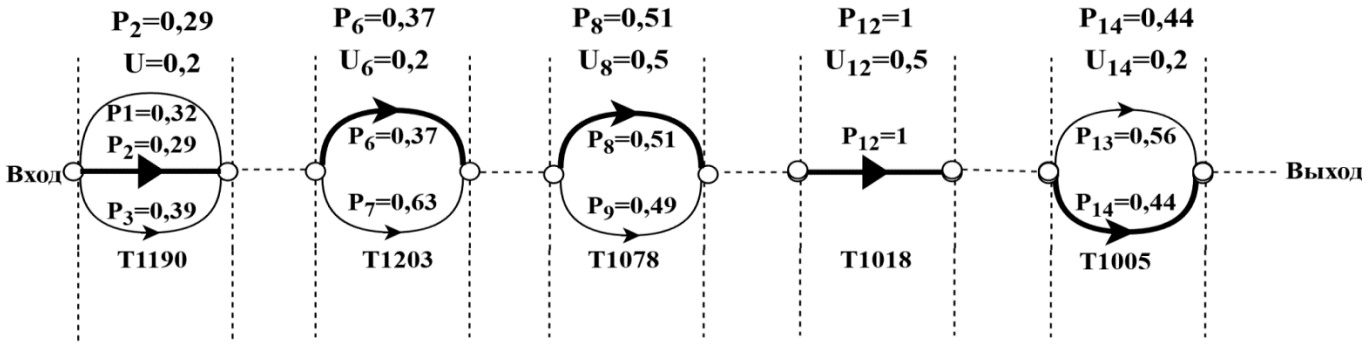


Рисунок 8 – Сценарий атаки шаблона CAPEC-387 с наименьшей оценкой риска

В таблице 34 приведены сценарии атаки по шаблону CAPEC-387 с оценкой риска более 0.1 (включая наибольшую оценку риска).

Таблица 34 – Сценарии шаблона CAPEC-387 с с наиболее существенными оценками риска

Сценарий	Риск
T1190 (CVE-2024-48916) -> T1203 (CVE-2025-24010) -> T1078 (CVE-2024-38325) -> T1018 (CVE-2024-41757) -> T1005 (CVE-2024-10460)	0.1403
> T1190 (CVE-2024-48916) -> T1203 (CVE-2025-24010) -> T1068 (CVE-2024-11159) -> T1018 (CVE-2024-41757) -> T1005 (CVE-2024-10460)	0.1321
T1190 (CVE-2024-48916) -> T1203 (CVE-2025-24010) -> T1068 (CVE-2024-52960) -> T1018 (CVE-2024-41757) -> T1005 (CVE-2024-10460)	0.1216
T1190 (CVE-2024-48916) -> T1059 (CVE-2024-49824) -> T1078 (CVE-2024-38325) -> T1018 (CVE-2024-41757) -> T1005 (CVE-2024-10460)	0.1158
T1190 (CVE-2020-26237) -> T1203 (CVE-2025-24010) -> T1078 (CVE-2024-38325) -> T1018 (CVE-2024-41757) -> T1005 (CVE-2024-10460)	0.1152
T1190 (CVE-2024-48916) -> T1203 (CVE-2025-24010) -> T1078 (CVE-2024-21245) -> T1018 (CVE-2024-41757) -> T1005 (CVE-2024-10460)	0.1146
T1190 (CVE-2024-48916) -> T1059 (CVE-2024-49824) -> T1068 (CVE-2024-11159) -> T1018 (CVE-2024-41757) -> T1005 (CVE-2024-10460)	0.1090

Сформируем сводную таблицу данных, для шаблона CAPEC-388 (табл.35).

Таблица 35 – Соответствие параметров вероятных сценариев реализации кибератаки шаблона CAPEC-388

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб уязвимости
CAPEC-388	T1595	CVE-2022-1525	0,750601	0,56	0,6
		CVE-2025-1838	0,594376	0,44	0,6
	T1190	CVE-2021-42701	0,742848	0,28	0,5
		CVE-2023-2904	0,587664	0,23	0,6
		CVE-2024-45410	0,738452	0,28	0,6
		CVE-2024-43108	0,552211	0,21	0,2
	T1059	CVE-2024-47123	0,582861	1	0,5
		ИЛИ			
	T1204	CVE-2024-47079	0,517972	1	0,75
	T1068	CVE-2023-38267	0,502929	0,23	0,2
		CVE-2023-50126	0,57304	0,27	0,2
		CVE-2024-24768	0,608861	0,28	0,2
		CVE-2024-25027	0,481287	0,22	0,2
	T1021	CVE-2022-22594	0,639248	0,44	0,2
		CVE-2020-24772	0,809175	0,56	0,6
		ИЛИ			
	T1210	CVE-2024-23922	0,532811	1	0,6
	T1005	CVE-2022-24762	0,503001	1	0,2

Представим таблицу 35 в виде графа на рисунке 9:

P_i – Вероятность успешной эксплуатации уязвимости.

Номера индексов соответствуют следующим уязвимостям:

1 - CVE-2022-1525; 2 - CVE-2025-1838; 3 - CVE-2021-42701;
4 - CVE-2023-2904; 5 - CVE-2024-45410; 6 - CVE-2024-43108;
7 - CVE-2024-47123; 8 - CVE-2024-47079; 9 - CVE-2023-38267;
10 - CVE-2023-50126; 11 - CVE-2024-24768; 12 - CVE-2024-25027;
13 - CVE-2022-22594; 14 - CVE-2020-24772; 15 - CVE-2024-23922;
16 - CVE-2022-24762.

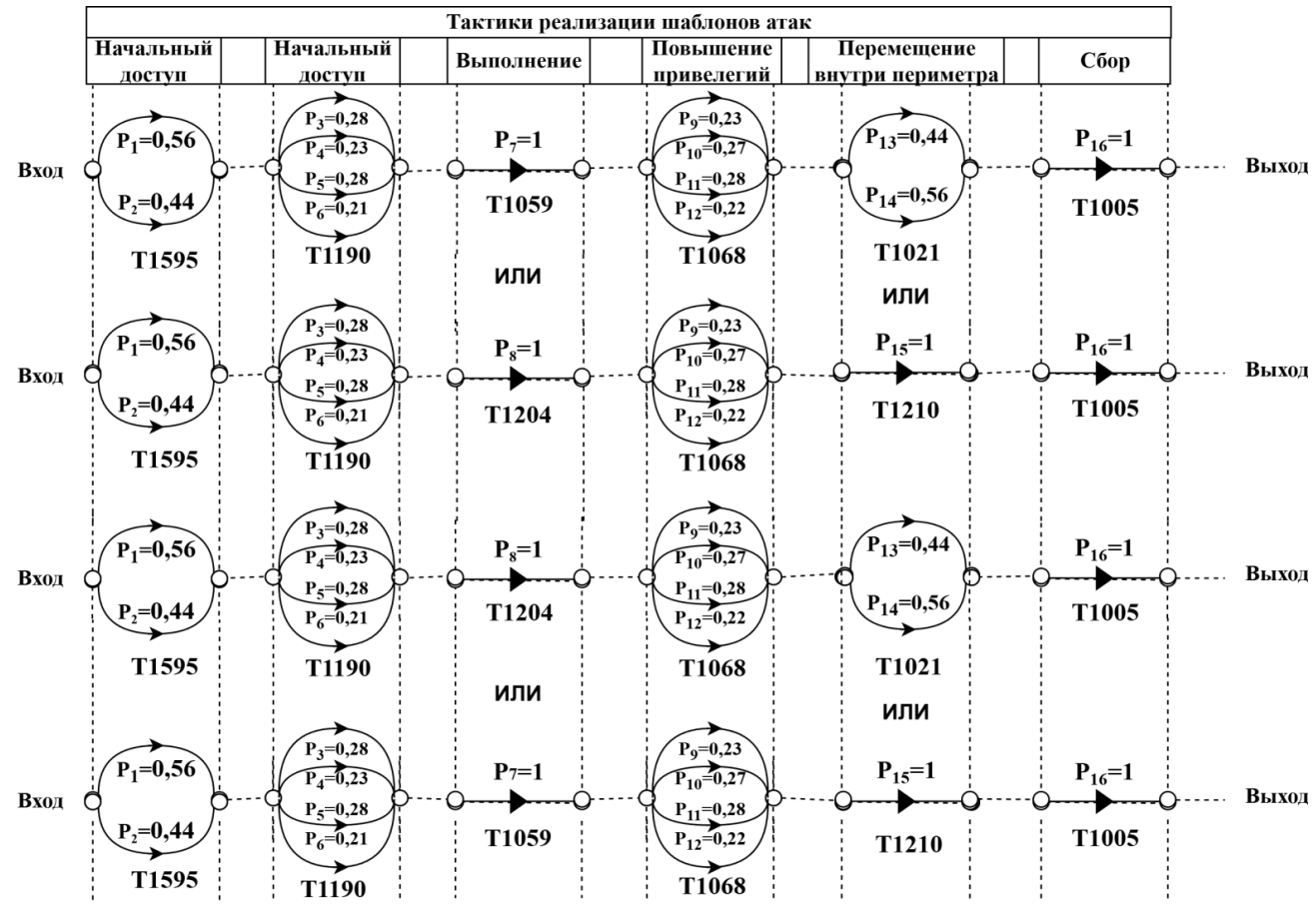


Рисунок 9 – Графовая модель вероятных сценариев реализации шаблона CAPEC-388

Проведём расчёт оценки риска и после представим с наиболее вероятный сценарий на рисунке 10:

$$Risk_{prob} = (0{,}56 * 0{,}28 * 1 * 0{,}28 * 1 * 1) * (0{,}6 * 2 + 0{,}5 + 0{,}75 + 0{,}2 * 2) = 0{,}1251.$$

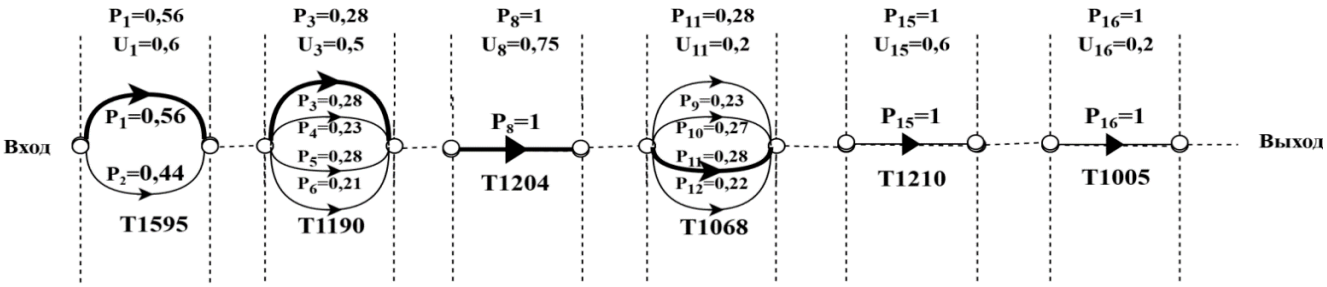


Рисунок 10 – Наиболее вероятный сценарий атаки шаблона CAPEC-388

Рассчитаем сценарии с наибольшей и наименьшей оценкой риска для CAPEC-388 и представим их на рисунках 11 и 12 соответственно:

$$Risk_{max} = (0{,}56 * 0{,}28 * 1 * 0{,}28 * 1 * 1) * (0{,}6 * 3 + 0{,}2 * 2 + 0{,}75) = 0{,}1295;$$

$$Risk_{min} = (0{,}44 * 0{,}21 * 1 * 0{,}22 * 0{,}44 * 1) * (0{,}5 + 0{,}6 + 0{,}2 * 4) = 0{,}0170.$$

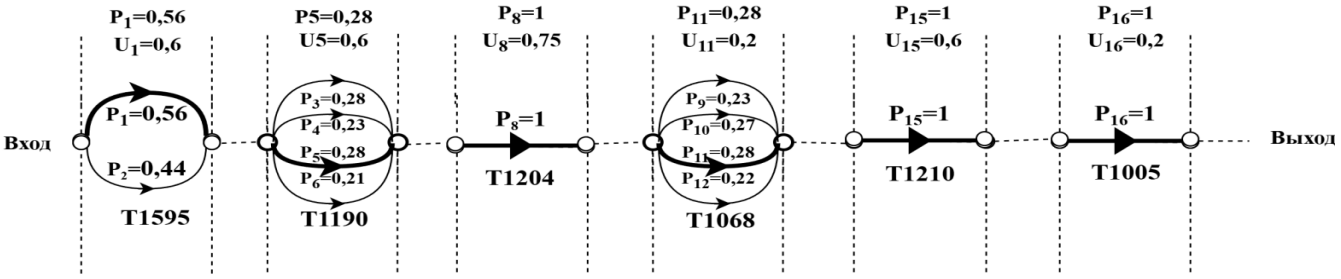


Рисунок 11 – Сценарий атаки шаблона CAPEC-388 с наибольшей оценкой риска

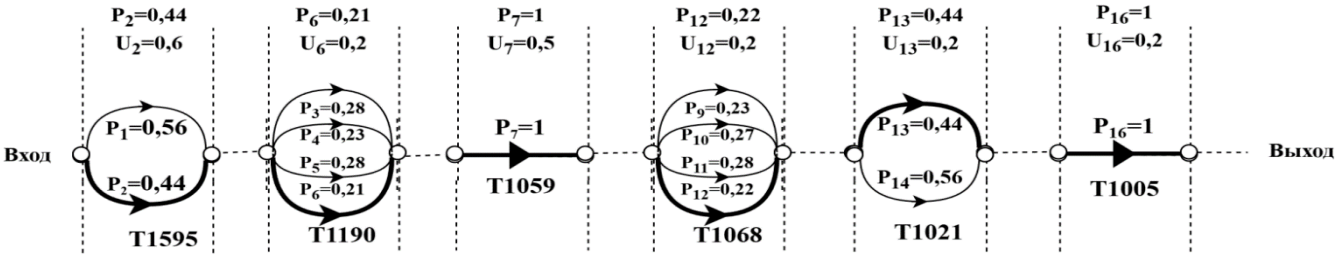


Рисунок 12 – Сценарий атаки шаблона CAPEC-388 с наименьшей оценкой риска

В таблице 36 приведены сценарии атаки по шаблону CAPEC-388 с оценкой риска более 0.1 (включая наибольшую оценку риска).

Таблица 36 – Сценарии CAPEC-388 с наиболее существенными оценками риска

Сценарий	Риск
T1595 (CVE-2022-1525) -> T1190 (CVE-2024-45410) -> T1204 (CVE-2024-47079) -> T1068 (CVE-2024-24768) -> T1210 (CVE-2024-23922) -> T1005 (CVE-2022-24762)	0.1295
T1595 (CVE-2022-1525) -> T1190 (CVE-2021-42701) -> T1204 (CVE-2024-47079) -> T1068 (CVE-2024-24768) -> T1210 (CVE-2024-23922) -> T1005 (CVE-2022-24762)	0.1251
T1595 (CVE-2022-1525) -> T1190 (CVE-2021-42701) -> T1204 (CVE-2024-47079) -> T1068 (CVE-2023-50126) -> T1210 (CVE-2024-23922) -> T1005 (CVE-2022-24762)	0.1249

Продолжение таблицы 36

Сценарий	Риск
T1595 (CVE-2021-22786) → T1190 (CVE-2022-0281) → T1068 (CVE-2021-3800) → T1555 (CVE-2024-47080) → T1083 (CVE-2022-34659) → T1213 (CVE-2022-34352)	0.1207
T1595 (CVE-2022-1525) -> T1190 (CVE-2024-45410) -> T1059 (CVE-2024-47123) -> T1068 (CVE-2024-24768) -> T1210 (CVE-2024-23922) -> T1005 (CVE-2022-24762)	0.1185
T1595 (CVE-2022-1525) -> T1190 (CVE-2024-45410) -> T1059 (CVE-2024-47123) -> T1068 (CVE-2023-50126) -> T1210 (CVE-2024-23922) -> T1005 (CVE-2022-24762)	0.1143

Сформируем сводную таблицу данных, для шаблона CAPEC-388 (табл.37).

Таблица 37 – Соответствие параметров вероятных сценариев реализации кибератаки шаблона CAPEC-662

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб уязвимости
CAPEC-662	T1190	CVE-2024-40715	0,605664	1	0,6
		ИЛИ			
	T1195.003	CVE-2024-30206	0,673184	1	0,6
	T1203	CVE-2025-23114	0,716436	0,27	0,75
		CVE-2024-39705	0,806145	0,3	0,6
		CVE-2024-39348	0,621182	0,23	0,75
		CVE-2024-27438	0,554956	0,2	0,75
		ИЛИ			
	T1204	CVE-2022-45442	0,728663	1	0,6
	T1574.002	CVE-2024-27263	0,571954	1	0,5
	T1557	CVE-2023-47742	0,529174	0,5	0,5
		CVE-2023-7008	0,51885	0,5	0,5
	T1495	CVE-2024-54126	0,694827	1	0,6

Представим таблицу 37 в виде графовой модели на рисунке 13:

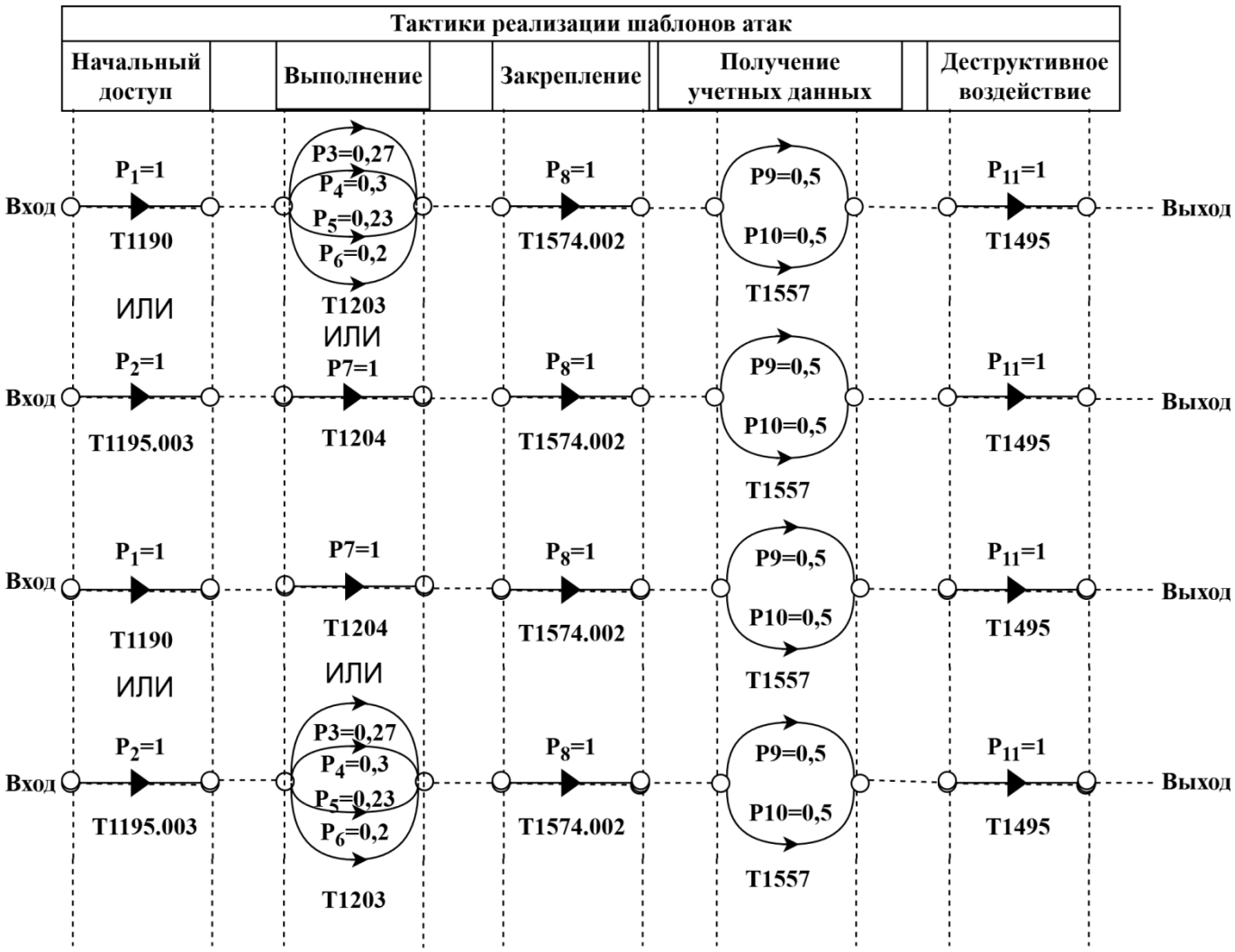


Рисунок 13 – Графовая модель вероятных сценариев реализации шаблона CAPEC-662

P_i – Вероятность успешной эксплуатации уязвимости.

Номера индексов соответствуют следующим уязвимостям:

1 - CVE-2024-40715; 2 - CVE-2024-30206; 3 - CVE-2025-23114;

4 - CVE-2024-39705; 5 - CVE-2024-39348; 6 - CVE-2024-27438;

7 - CVE-2022-45442; 8 - CVE-2022-45442; 9 - CVE-2024-27263;

10 - CVE-2023-47742; 11 - CVE-2023-7008; 12 - CVE-2024-54126

Для данного шаблона существует 48 возможных сценариев. Самый вероятный из них в тоже время является и самым рисковым. Рассчитаем риск и представим этот сценарий на рисунке 14:

$$Risk_{max} = (1 * 1 * 1 * 0{,}5 * 1) * (0{,}6 * 0{,}6 + 0{,}5 + 0{,}5 + 0{,}5 + 0{,}6) = 1{,}5250.$$

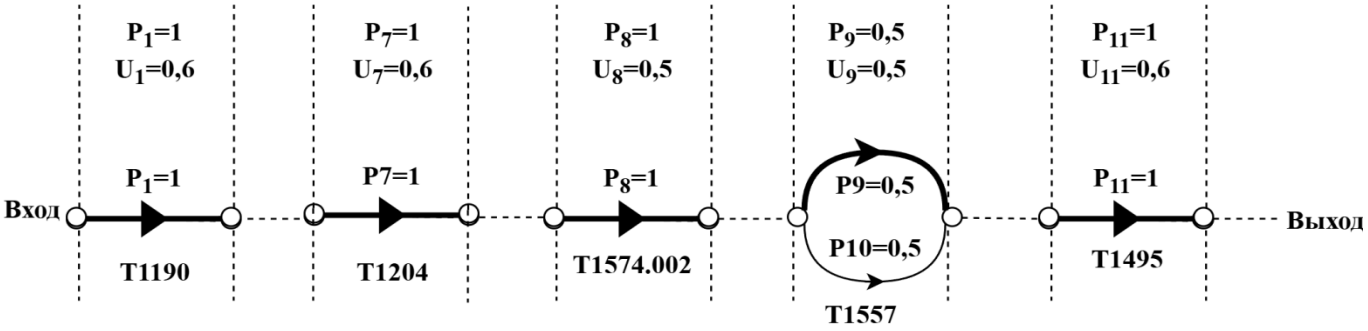


Рисунок 14 – Сценарий атаки шаблона CAPEC-662 с наибольшей оценкой риска

Используя формулу (11), найдём сценарий с минимальным риском и представим его на рисунке 15:

$$Risk_{min} = (1 * 0{,}2 * 1 * 0{,}5 * 1) * (0{,}6 + 0{,}75 + 0{,}5 + 0{,}5 + 0{,}6) = 0{,}295.$$

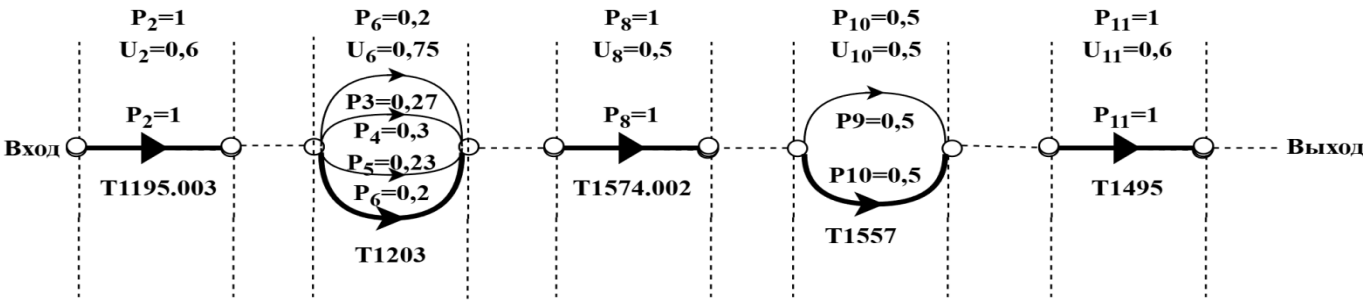


Рисунок 15 – Сценарий атаки шаблона CAPEC-662 с наименьшей оценкой риска

В таблице 38 приведены сценарии атаки по шаблону CAPEC-662 с оценкой риска более 0.1 (включая наибольшую оценку риска).

Таблица 36 – Сценарии CAPEC-662 с наиболее существенными оценками риска

Сценарий	Риск
T1190 (CVE-2024-40715) -> T1204 (CVE-2022-45442) -> T1574.002 (CVE-2024-27263) -> T1557 (CVE-2023-47742) -> T1485 (CVE-2024-54126)	1.5250
T1190 (CVE-2024-40715) -> T1204 (CVE-2022-45442) -> T1574.002 (CVE-2024-27263) -> T1557 (CVE-2023-7008) -> T1485 (CVE-2024-54126)	1.5250
T1195.003 (CVE-2024-30206) -> T1204 (CVE-2022-45442) -> T1574.002 (CVE-2024-27263) -> T1557 (CVE-2023-47742) -> T1485 (CVE-2024-54126)	1.5250
T1195.003 (CVE-2024-30206) -> T1204 (CVE-2022-45442) -> T1574.002 (CVE-2024-27263) -> T1557 (CVE-2023-7008) -> T1485 (CVE-2024-54126)	1.5250
T1190 (CVE-2024-40715) -> T1203 (CVE-2024-39705) -> T1574.002 (CVE-2024-27263) -> T1557 (CVE-2023-47742) -> T1485 (CVE-2024-54126)	0.4575
T1190 (CVE-2024-40715) -> T1203 (CVE-2024-39705) -> T1574.002 (CVE-2024-27263) -> T1557 (CVE-2023-7008) -> T1485 (CVE-2024-54126)	0.4575
T1195.003 (CVE-2024-30206) -> T1203 (CVE-2024-39705) -> T1574.002 (CVE-2024-27263) -> T1557 (CVE-2023-47742) -> T1485 (CVE-2024-54126)	0.4575

Сформируем сводную таблицу данных для шаблона CAPEC-701 (табл.39) и граф вероятных сценариев (рис.16).

Таблица 39 – Соответствие параметров вероятных сценариев реализации кибератаки шаблона CAPEC-701

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб уязвимости
CAPEC-701	T1190	CVE-2022-48507	0,645717	0,47	0,2
		CVE-2023-20900	0,735062	0,53	0,75
		ИЛИ			
	T1203	CVE-2023-45292	0,593982	1	0,2
	T1059	CVE-2022-46480	0,753883	1	0,2
		ИЛИ			
	T1505	CVE-2023-41890	0,62515	1	0,2

Продолжение таблицы 39

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб уязвимости
	T1068	CVE-2023-44402	0,7023	0,28	0,75
		CVE-2023-51655	0,752446	0,31	0,6
		CVE-2023-51764	0,54246	0,22	0,2
		CVE-2023-51765	0,465499	0,19	0,2
	T1021	CVE-2023-48238	0,6634	1	0,2
	T1185	CVE-2023-49087	0,626448	1	0,2

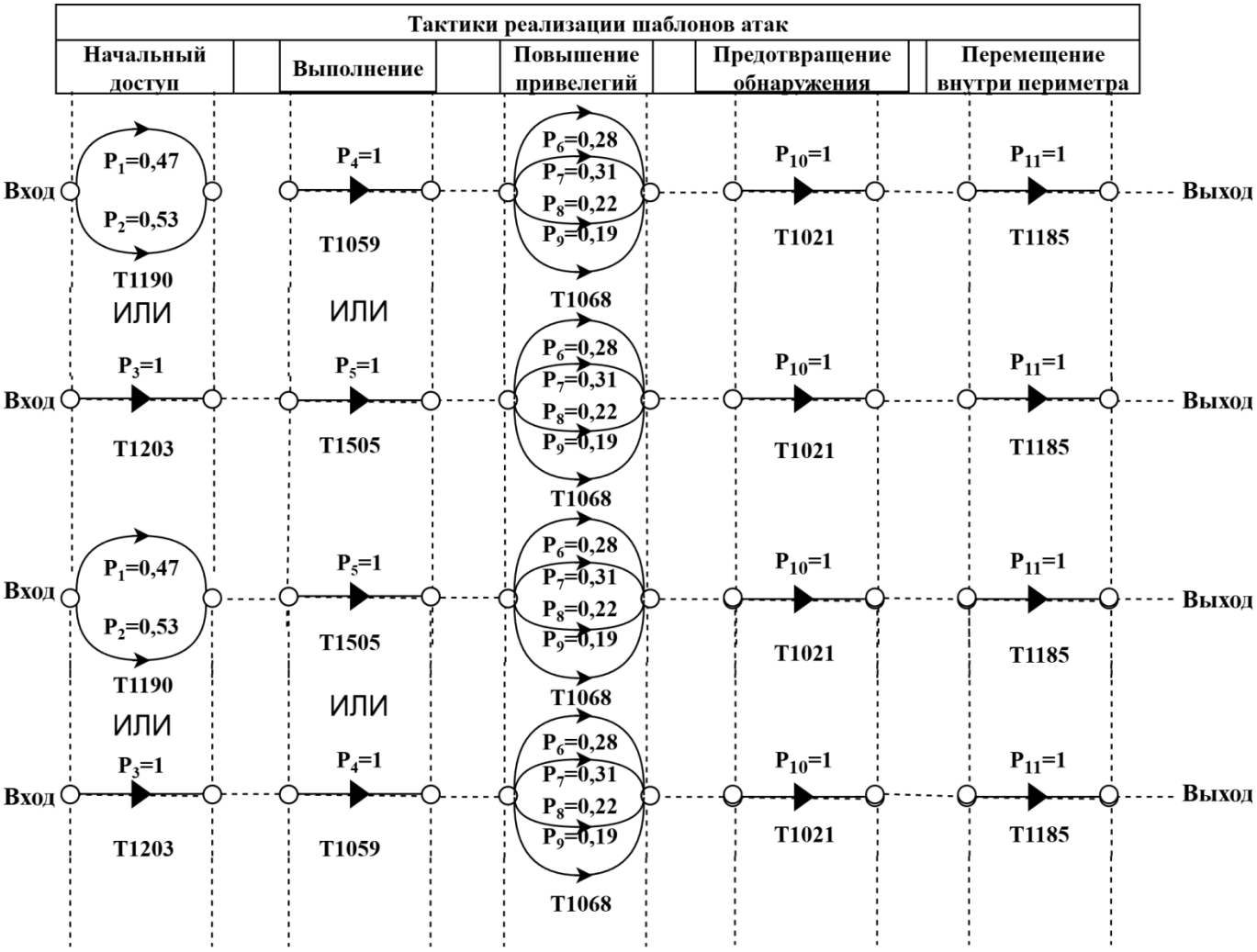


Рисунок 16 – Графовая модель вероятных сценариев реализации шаблона CAPEC-701

P_i – Вероятность успешной эксплуатации уязвимости.

Номера индексов соответствуют следующим уязвимостям:

1 - CVE-2022-48507; 2 - CVE-2023-20900; 3 - CVE-2023-45292;

4 - CVE-2022-46480; 5 - CVE-2023-41890; 6 - CVE-2023-44402;

7 - CVE-2023-51655; 8 - CVE-2023-51764; 9 - CVE-2023-51765;

10 - CVE-2023-48238; 11 - CVE-2023-49087

Из 32 возможных сценариев наиболее вероятный показан на рисунке 17.

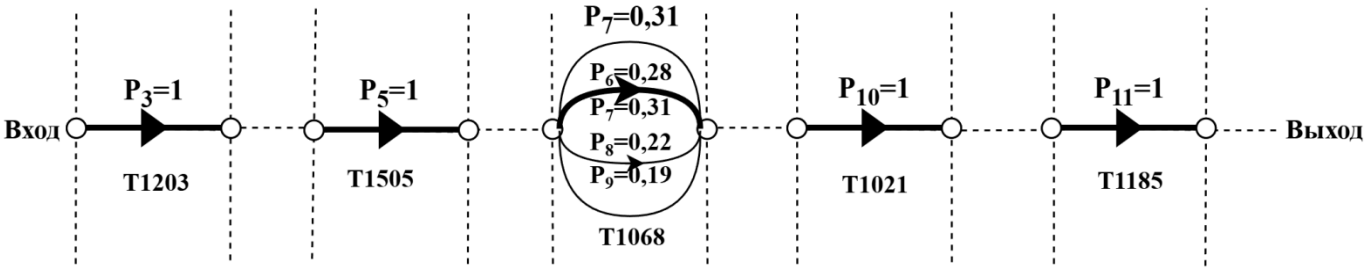


Рисунок 17– Наиболее вероятный сценарий атаки шаблона CAPEC-701

Сценарий с максимальной оценкой риска (рис.18): T1203 (CVE-2023-45292) -> T1059 (CVE-2022-46480) -> T1068 (CVE-2023-51655) -> T1021 (CVE-2023-48238) -> T1185 (CVE-2023-49087). Расчёт риска для него:

$$Risk_{max} = (1 * 1 * 0{,}31 * 1 * 1) * (0{,}2 + 0{,}2 + 0{,}6 + 0{,}2 + 0{,}2) = 0{,}3205$$

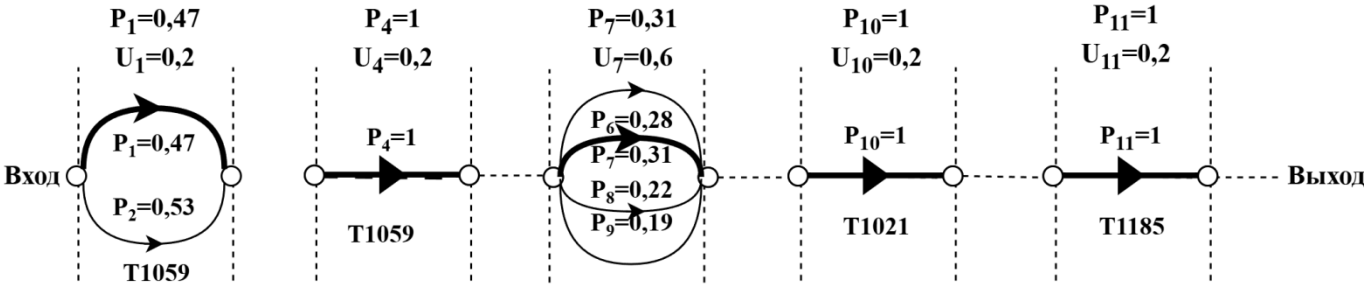


Рисунок 18– Сценарий атаки шаблона CAPEC-701 с наибольшей оценкой риска

Сценарий с минимальной оценкой риска показан на рисунке 19. Его расчетное значение:

$$Risk_{min} = (0{,}47 * 1 * 0{,}19 * 1 * 1 * 1) * (0{,}2 * 5) = 0{,}0893.$$

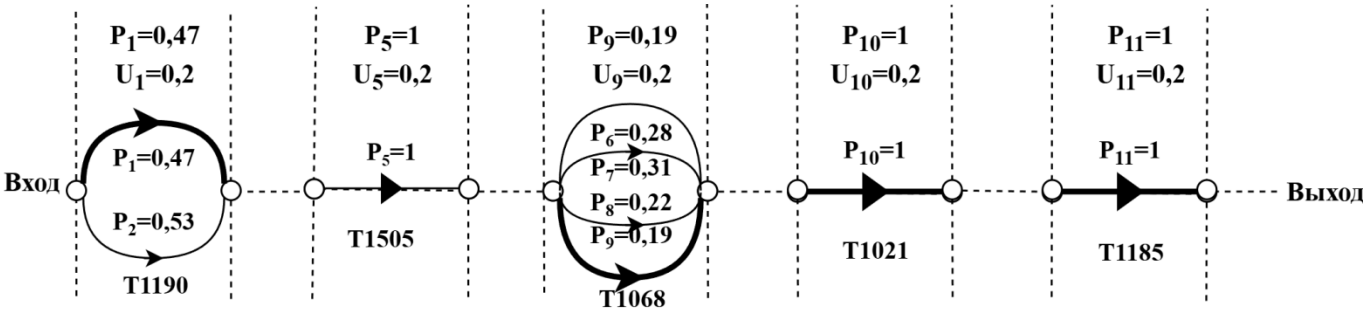


Рисунок 19 – Сценарий атаки шаблона CAPEC-701 с наименьшей оценкой риска

В таблице 40 приведены сценарии атаки по шаблону CAPEC-701 с оценкой риска более 0.1 (включая наибольшей оценкой риска).

Таблица 38 – Сценарии CAPEC-701 с наиболее существенными оценками риска

Сценарий	Риск
T1203 (CVE-2023-45292) -> T1059 (CVE-2022-46480) -> T1068 (CVE-2023-44402) -> T1021 (CVE-2023-48238) -> T1185 (CVE-2023-49087)	0.4340
T1203 (CVE-2023-45292) -> T1059 (CVE-2022-46480) -> T1068 (CVE-2023-51655) -> T1021 (CVE-2023-48238) -> T1185 (CVE-2023-49087)	0.4340
T1190 (CVE-2023-20900) -> T1059 (CVE-2022-46480) -> -> T1068 (CVE-2023-51655) -> T1021 (CVE-2023-48238) -> T1185 (CVE-2023-49087)	0.4340
T1190 (CVE-2023-20900) -> T1059 (CVE-2022-46480) -> T1068 (CVE-2023-44402) -> T1021 (CVE-2023-48238) -> T1185 (CVE-2023-49087)	0.4340
T1203 (CVE-2023-45292) -> T1059 (CVE-2022-46480) -> T1068 (CVE-2023-51764) -> T1021 (CVE-2023-48238) -> T1185 (CVE-2023-49087)	0.3204
T1190 (CVE-2022-48507) -> T1059 (CVE-2022-46480) -> T1068 (CVE-2023-51655) -> T1021 (CVE-2023-48238) -> T1185 (CVE-2023-49087)	0.3204

4 Разработка организационно-правовых регламентов защиты для снижения рисков реализации атак класса «Злоумышленник посередине»

Организационно-правовые регламенты играют важную роль в обеспечении эффективного реагирования на инциденты информационной безопасности в современных автоматизированных системах.

Методология разработки мер реагирования и ликвидации последствий инцидентов основывалась на анализе информации из авторитетных открытых источников, включая базы данных CAPEC, MITRE ATT&CK, БДУ ФСТЭК России, NIST и специализированные тематические ресурсы. Эти источники предоставляют сведения о методах атак, их характеристиках и соответствующих уязвимостях, а также содержат рекомендации по предотвращению и устранению последствий атак. Кроме того, при разработке регламентов использовались нормативные и методические документы в области информационной безопасности, что позволяет учитывать требования российского законодательства и международных стандартов.

На основе описанных в предыдущих главах этапных сценариев атак, построенных с использованием шаблонов и техник MITRE ATT&CK, были выделены инциденты, которые отражают взаимосвязь между используемыми векторами атак и соответствующими уязвимостями. Такой подход позволяет сформировать регламенты, ориентированные на специфику каждого сценария, с чётко обозначенными мерами реагирования и устранения последствий.

Такой подход упорядочивает комплекс мероприятий по предотвращению атак и нейтрализации их последствий, снижая вероятность успешной реализации угроз и повышая общий уровень защищённости информационных систем.

Пример структуризации организационных регламентов по реагированию и ликвидации последствий MitM-атак для шаблона CAPEC-387 приведен в таблице 41. Организационные регламенты для остальных трех шаблонов приведены в приложении А (табл. А1-А3).

Таблица 41 – Организационные регламенты для шаблона CAPEC-387

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Первоначальный доступ	Тактика первоначального доступа реализуется через технику T1190. Эксплуатируя уязвимость CVE-2020-26237 в HTTP-запросах, появляются поля вроде «proto» и «constructor», что вызывает ошибки, уязвимость CVE-2025-25188 в приложении Hickory позволяет подделывать IP-адреса в ответах, CVE-2024-48916 даёт злоумышленникам несанкционированный доступ к хранилищу.	1. На уровне WAF блокировать все запросы с подозрительными полями. 2. Включить аудит логов подсистем подсветки кода. 3. При признаках подмены DNS – изолировать узлы.	1. Обновить ПО highlight.js до версии выше 9.18.2, Hickory до версии 0.24.3 и выше, RadosGW до новейшей версии. 2. Установить белый список используемых языков/HTML-тегов и IP-адресов. 3. Проверить код на следы эксплуатации нарушителя и исправить это.
Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Выполнение	Техника T1203 эксплуатирует уязвимости: CVE-2025-21511 – доступ к данным при сетевом запросе; CVE-2025-24010 – разрешает любым сайтам отправлять запросы серверу разработчика и читать ответы. Техника T1059 эксплуатирует уязвимости: CVE-2024-51462, что ведёт к нарушению целостности данных при парсинге XML; CVE-2024-49824 позволяет аутентифицированным пользователям выполнять действия класса выше.	1. Заблокировать странные HTTP-запросы с помощью брандмауэра. 2. Включить логирование WebSocket соединений. 3. Провести анализ, завершить подозрительные скрипты, а также изолировать заражённые узлы.	1. Установить патчи, устраняющие уязвимости. 2. Установить белый список доверенных HTTP-адресов. 3. Проанализировать HTML и добавить подписи кода скриптов.

Продолжение таблицы 41

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Повышение привилегий	Техника T1078 эксплуатирует уязвимости: CVE-2024-38325 – отправка CLI запросов по небезопасному каналу; CVE-2024-21245 – позволяет атакующему с меньшими правами, изменять и читать данные приложения. Через технику T1068 происходит эксплуатация: CVE-2024-52960 в ПО Fortinet, позволяет обходить серверные ограничения через скрипты; CVE-2024-11159 в Mozilla Thunderbird разглашает зашифрованные сообщения.	1. Через брандмауэр заблокировать все аномальные CLI-запросы и странные HTTP-векторы. 2. Включить аудит по вызовам защитника и HTTP-запросам. 3. Изолировать подозрительный узел и завершить процессы внутри.	1. Обновить ПО: IBM Storage Defender до версии 2.0.8, Oracle JD Edwards Tools до 9.2.9.0, FortiSandbox до 5.0.1 и Thunderbird до 128.4.3/132.0.1. 2. Автоматизировать управление патчами и верификацию. 3. Настроить брандмауэр на блокировку характерных следов уязвимостей.
Обнаружение	Техника T1018 эксплуатирует уязвимость CVE-2024-41757. Позволяет злоумышленнику через MITM-перехват получать передаваемые данные в незашифрованных HTTP-сессиях.	1. Сканировать аномальные отправки запросов, характерные злоумышленнику посередине. 2. При подтверждении перехвата, блокировать HTTP-трафик.	1. Включить защиту от злоумышленника посередине с помощью конфигурации ПО IBM Consert. 2. Обновить настройки брандмауэра.
Сбор	Тактика сбора реализуется через технику T1005: уязвимость CVE-2019-3980 позволяет злоумышленнику совершить чтение множества файлов документов; CVE-2024-10460 в Firefox злоумышленник скрывает протокол и вызывает сбор локальных ресурсов.	1. Изолировать хост от сети, сохранить память и копии затронутых файлов. 2. Временно отключить работу уязвимых программ. 3. Заблокировать подозрительные файлы и скрипты с помощью программ для реагирования на угрозы.	1. Установить обновления, исправляющие уязвимости. 2. Настроить политики контроля приложений и доступа. 3. Проверить целостность файлов и восстановить их из резервных копий.

ЗАКЛЮЧЕНИЕ

В ходе проведенного исследования была достигнута поставленная цель – повышение защищенности АИС посредством развития методического обеспечения риск-анализа атак класса «Злоумышленник посередине», благодаря полученным в ходе исследований следующим результатам:

– создана база детализированных и стандартизированных описаний сценариев атак класса «Злоумышленник посередине»;

– выработана методика риск-анализа атак класса «Злоумышленник посередине», систематизированных по сценариям, тактикам, техникам и эксплуатируемым уязвимостям;

– разработан комплекс регламентов реагирования и ликвидации последствий в отношении атак класса «Злоумышленник посередине» на АИС.

Полученные оценки рисков успешной реализации рассмотренных в работе шаблонов MitM-атак открывают возможности их минимизации в целях повышения защищенности атакуемых систем. Таблицы с рассчитанными в работе показателями могут быть интегрированы в системы реагирования на инциденты для автоматического формирования правил детектирования и коррекции уязвимостей, связанных с перехватом и модификацией трафика.

Выработанный инструментарий анализа сценариев MitM-атак открывает перспективы для построения адаптивной защиты АИС. Например, возможность ранжирования уязвимостей по критичности и вероятности их эксплуатации позволяет приоритизировать внедрение защитных мер с упором на отражение наиболее значимых угроз. Такой подход снижает избыточность затрат на защиту и обеспечивает эффективное использование имеющихся ресурсов.

Разработанное методическое обеспечение риск-анализа интегрирует существующие и перспективные аналитические и практические подходы и дает возможность прогнозирования сценариев атак на основе расчета вероятностей и ущербов успешной реализации конкретных тактик и техник, что позволяет

обеспечивать высокий уровень точности в оценке рисков и выявлять узкие места в защите АИС ещё до возникновения инцидентов.

Регламенты реагирования и ликвидации последствий, сформированные на основе сценариев MitM-атак, позволяют оперативно идентифицировать инциденты и минимизировать ущерб, связанный с эксплуатацией выявленных уязвимостей.

Разработанные регламенты стандартизируют процесс реагирования на зарегистрированные инциденты, включая конкретные шаги, такие как изоляция уязвимых сервисов, внедрение обновлений и проверка целостности конфигураций. Это исключает хаотичность действий персонала в ходе отражения атак и обеспечивает системность применения мер защиты, что в результате повышает их эффективность. Например, на этапе реагирования на регистрируемые инциденты предложены конкретные способы настройки классических межсетевых экранов и фаерволов нового поколения (WAF), препятствующие использованию техник модификации сетевого трафика.

Методика ликвидации последствий атак, представленная в регламентах, ориентирована не только на восстановление нормальной работы АИС после атаки, но и на предотвращение повторных инцидентов, в том числе путем модернизации ИТ-инфраструктуры и повышению её устойчивости. Например, рекомендации по актуализации политик безопасности, обновлению программного обеспечения, внедрению «белых списков», перенастройке межсетевых экранов позволяют закрыть выявленные уязвимости и существенно усложнить эксплуатацию аналогичных.

Таким образом, предложенное методическое обеспечение риск-анализа и регламенты формируют единую основу для анализа, прогнозирования и предотвращения атак класса «Злоумышленник посередине».

СПИСОК ЛИТЕРАТУРЫ

1 Эпидемии в телекоммуникационных сетях / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. (Серия «Теория сетевых войн»; вып. 1). – 284 с. – Текст: непосредственный.

2 Атакуемые взвешенные сети / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. (Серия «Теория сетевых войн»; вып. 2). – 284 с. – Текст: непосредственный.

3 Социальные сети и деструктивный контент / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. (Серия «Теория сетевых войн»; вып. 3). – 284 с. – Текст: непосредственный.

4 Социальные сети и риск-мониторинг / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2019. (Серия «Теория сетевых войн»; вып. 4). – 284 с. – Текст: непосредственный.

5 Социальные сети и психологическая безопасность / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2020. (Серия «Теория сетевых войн»; вып. 5). – 284 с. – Текст: непосредственный.

6 Сетео-информационная эпидемиология / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2021. (Серия «Теория сетевых войн»; вып. 6). – 284 с. – Текст: непосредственный.

7 Картография защищаемого киберпространства / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2022. (Серия «Теория сетевых войн»; вып. 7). – 372 с. – Текст: непосредственный.

8 Организационно-правовая защита сетей / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2023. (Серия «Теория сетевых войн»; вып. 8). – 228 с. – Текст: непосредственный.

9 Актуальные киберугрозы. – Электрон. Дан. – Режим доступа: https://www.ptsecurity.com/ru-ru/research/analytics/aktualnye-kiberugrozy-iv-kvartal-2024-goda-i-kvartal-2025-goda/. – Текст: электронный.

10 CAPEC. – Электрон. Дан. – Режим доступа: https://capec.mitre.org/. – Текст: электронный.

11 MITRE ATT&CK. – Электрон. дан. – Режим доступа: https://attack.mitre.org/matrices/enterprise/. – Текст: электронный.

12 PT Security MITRE. – Электрон. дан. – Режим доступа: https://mitre.ptsecurity.com/ru-RU. – Текст: электронный.

13 MITRE EMB3D. – Электрон. дан. – Режим доступа: https://emb3d.mitre.org/. – Текст: электронный.

14 ATLAS MITRE. – Электрон. дан. – Режим доступа: https://atlas.mitre.org/. – Текст: электронный.

15 ATLAS SecurityHub. – Электрон. дан. – Режим доступа: https://atlas.securityhub.ru/. – Текст: электронный.

16 База данных угроз ФСТЭК (BDU). – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/threat. – Текст: электронный.

17 Центр безопасности данных. – Электрон. Дан. – Режим доступа: https://data-sec.ru/personal-data/threats-data-bank. – Текст: электронный.

18 Национальный координационный центр по компьютерным инцидентам. – Электрон. дан. – Режим доступа: https://cert.gov.ru/. – Текст: электронный.

19 NVD. – Электрон. дан. – Режим доступа: https://nvd.nist.gov/. – Текст: электронный.

20 CVE. – Электрон. дан. – Режим доступа: https://www.cve.org/. – Текст: электронный.

21 CVSS. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/. – Текст: электронный.

22 CVSS v3.1. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v3-1/. – Текст: электронный.

23 CVSS v4.0. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v4-0/. – Текст: электронный.

24 EPSS. – Электрон. дан. – Режим доступа: https://www.first.org/epss. – Текст: электронный.

25 OWASP Risk Rating. – Электрон. дан. – Режим доступа: https://owasp-risk-rating.com/. – Текст: электронный.

26 CISA SSVC Calculator. – Электрон. дан. – Режим доступа: https://www.cisa.gov/ssvc-calculator. – Текст: электронный.

27 VISS CVSS Calculator. – Электрон. дан. – Режим доступа: https://viss.zoom.com/calculator/. – Текст: электронный.

28 Halborn BVSS. – Электрон. дан. – Режим доступа: https://www.halborn.com/bvss. – Текст: электронный.

29 HVSS Online. – Электрон. дан. – Режим доступа: https://hvss.online/. – Текст: электронный.

30 Оценка критичности уязвимостей с использованием данных множества риск-калькуляторов / А. А. Остапенко, В. П. Шелякин, Е. С. Короткова [и др.] // Информация и безопасность. – 2024. – Т. 27, № 4. – С. 521-542. – Текст: непосредственный.

31 Остапенко А. А. Актуальные задачи и некоторые их решения в части риск-калькуляции успешности реализации единичных кибератак / А. А. Остапенко // Информация и безопасность. – 2024. – Т. 27, № 4. – С. 543-552. – Текст: непосредственный.

32 Остапенко А. А. Методики и алгоритмы риск-анализа успешности реализации массированных кибератак / А. А. Остапенко // Информация и безопасность. – 2024. – Т. 27, № 3. – С. 401-420. – Текст: непосредственный.

33 Остапенко Г. А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть I) / Г. А. Остапенко, А. П. Васильченко, А. А. Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 1. – С. 7-30. – Текст: непосредственный.

34 Остапенко Г. А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть II) / Г. А. Остапенко, А. П. Васильченко, А. А. Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 1. – С. 31-54. – Текст: непосредственный.

35 Остапенко Г. А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть I) / Г. А. Остапенко, А. П. Васильченко, А. А.

Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 3. – С. 319-338. – Текст: непосредственный.

36 Остапенко Г. А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть II) / Г. А. Остапенко, А. П. Васильченко, А. А. Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 3. – С. 339-378. – Текст: непосредственный.

37 Остапенко Г. А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть III) / Г. А. Остапенко, А. П. Васильченко, А. А. Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 4. – С. 477-488. – Текст: непосредственный.

38 Остапенко Г. А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть IV) / Г. А. Остапенко, А. П. Васильченко, А. А. Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 4. – С. 489-508. – Текст: непосредственный.

39 Остапенко Г. А. Модернизация методического обеспечения автоматизированного сервиса агрегации данных и риск-анализа уязвимостей / Г. А. Остапенко, А. П. Васильченко, А. А. Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 2. – С. 219-230. – Текст: непосредственный.

40 Остапенко Г. А. Формализация знаний и данных кибератак и уязвимостей / Г. А. Остапенко, А. П. Васильченко, А. А. Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 2. – С. 231-238. – Текст: непосредственный.

ПРИЛОЖЕНИЕ А

Таблица А1 – Организационные регламенты для шаболна CAPEC-388

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Разведка	Тактика разведка реализуется через технику T1595. Эксплуатируя уязвимость CVE-2022-1525 - уязвимость в модуле анализа сетевых пакетов, позволяла обходить фильтры и собирать подробную информацию о службах без детектирования; уязвимость CVE- CVE-2025-1838 баг в библиотеке обнаружения сервисов, позволяющий отправлять специально сформированные запросы для индикации открытых портов.	1. Настроить IDS/IPS на выявление аномальных порт- и протокольных сканирований. 2. Формировать оповещения при превышении порога соединений на один IP за короткий интервал. 3. Блокировать подозрительные адреса на периметровом фаерволе.	1. Установить патчи, закрывающие CVE-2022-1525 и CVE-2025-1838. 2. Внедрить сегментацию сети, ограничивающую объём доступных хостов для сканирования.3. Развернуть honeypot для изучения методов сканирования
Первоначальный доступ	Техника T1190 эксплуатирует уязвимости: CVE-2021-42701– позволяющая удалённо выполнить произвольный код через специально сформированный HTTP-запрос; CVE-2023-2904– ошибка в API публичного портала, обходящая аутентификацию; CVE-2024-45410 - уязвимость в мобильном интерфейсе приложения, раскрывающая административные функции; CVE-2024-43108 XSS-уязвимость в панели управления, позволяющая захватить сессионные токены	1. На уровне WAF блокировать запросы с отладочными/нетиповыми параметрами. 2. Включить подробный аудит веб-запросов (URI, User-Agent, referer). 3. При детекции эксплойтов – изолировать веб-сервер	1. Обновить уязвимые приложения до версий, закрывающих все перечисленные CVE.2. Ввести белый список разрешённых параметров и экранировать ввод.3. Провести код-ревю наиболее критичных модулей.

Продолжение таблицы А1

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Исполнение	Техника T1059 эксплуатирует уязвимости: CVE-2024-47123 баг в интерпретаторе Bash, позволяющий выполнить произвольные команды из удалённо подгруженного скрипта. Через технику T1204 происходит эксплуатация: CVE-2024-47079 уязвимость в клиентском приложении, требующая от пользователя открыть вредоносный файл, после чего происходит запуск встроенного кода.	1. Мониторить запуск новых процессов командной строки и скриптов через EDR. 2. Ограничить исполнение только утверждённых bin/shell-файлов (Application Control). 3. При обнаружении – завершить подозрительные процессы.	1. Установить патчи для CVE-2024-47123 и CVE-2024-47079. 2. Настроить политики групповой политики (GPO/AppLocker) на запрет неавторизованных скриптов. 3. Инструктировать пользователей по идентификации фишинговых запусков.
Повышение привилегий	Техника T1068 эксплуатирует уязвимости: CVE-2023-38267 - переполнение буфера в драйвере Windows, позволяющее получить системные привилегии; CVE-2023-50126 - ошибка в подсистеме контроля доступа NTFS, обходимая локально; CVE-2024-24768 уязвимость в менеджере учётных записей, позволяющая подделать токены безопасности; CVE-2024-25027 - баг в ядре Linux, дающий возможность эскалации до root.	1. Анализировать журналы Windows Security и sudo-аудит на подозрительные запросы токенов. 2. EDR/AV – блокировать известные эксплойт-бинарники. 3. Изолировать узел при попытках локального эскалационного кода.	1. Применить обновления для всех затронутых компонентов. 2. Установить принцип наименьших привилегий (least privilege) для сервисных и пользовательских аккаунтов. 3. Регулярно проверять и удалять неиспользуемые учётные записи.
Перемещение внутри периметра	Техника T1021 эксплуатирует уязвимости: CVE-2022-22594 критическая уязвимость в RDP, позволяющая произвольно подключаться без корректной аутентификации; CVE-2020-24772 - баг в SSH-агенте, раскрывающий ключи при определённых условиях. Через технику T1210 происходит эксплуатация: CVE-2024-23922 - ошибка в службе обмена сообщениями, дающая возможность удалённого исполнения кода.	1. Сигнатуры IDS/IPS на RDP/SSH/SMB-эксплойты, мониторинг нетипичных подключений. 2. При аномалиях – принудительно разрывать сессии и изолировать исходный хост. 3. Проверять нетипичные учётные данные/местоположения входа.	1.Закрыть уязвимые сервисы удалённого доступа. 2. Включить многофакторную аутентификацию для всех сервисов. 3. Внедрить огороженную сеть (network zoning) с минимальными правами межсегментного трафика.

Продолжение таблицы А1

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Сбор	Техника T1005 эксплуатирует уязвимости: CVE-2022-24762- уязвимость в локальной утилите сбора логов, позволяющая извлекать и передавать конфиденциальные файлы без ограничения доступа.	1. Отслеживать массовое чтение/копирование файлов чувствительных директорий (DLP/EDR). 2. Формировать оповещения при записи большого объёма данных на внешние носители. 3. При аномалии – изолировать хост и собрать дамп памяти.	1. Установить обновление, устраняющее CVE-2022-24762. 2. Настроить ограничение доступа к критичным файлам через ACL и DLP-политику. 3. Проверить целостность файлов, восстановить из резервных копий при необходимости.

Таблица А2 – Организационные регламенты CAPEC-662

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Первоначальный доступ	Тактика первоначального доступа реализуется через технику T1190. Эксплуатируя уязвимость CVE-2025-23114- – уязвимость в процессе сборки ПО, позволяющая подменить библиотеку на вредоносную при сборке дистрибутива. Техника T1195.003 эксплуатирует уязвимость CVE-2024-30206 баг в компоненте стороннего поставщика приводил к раскрытию конфиденциальных данных при загрузке обновлений.	1. Настроить WAF и IDS/IPS на выявление попыток эксплуатации CVE-2024-40715 и аномальных HTTP-запросов к критичным API. 2. Мониторить целевые репозитории и каналы поставки на неожиданные изменения или неавторизованные сборки. 3. При обнаружении подозрительной активности — изолировать затронутый узел.	1. Обновить все уязвимые компоненты до версий, закрывающих CVE-2024-40715 и CVE-2024-30206. 2. Внедрить проверку цифровых подписей. 3. Пересобрать и переподписать ПО из проверенных исходных кодов и доверенных каналов поставки.

Продолжение таблицы А2

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Выполнение	Техника T1203 эксплуатирует уязвимости: CVE-2025-23114 – уязвимость в процессе сборки ПО, позволяющая подменить библиотеку на вредоносную при сборке дистрибутива CVE-2024-39705 – ошибка в обработке документов офисного пакета, дающая возможность запускать произвольные скрипты при открытии файла. CVE-2024-39348 – уязвимость в плагине мультимедиа для браузера, позволяющая выполнить код через специально сформированный поток. CVE-2024-27438 – баг в библиотеке отображения графики, приводящий к переполнению буфера и удалённому исполнению шелл-команд. Техника T1204 эксплуатирует уязвимость: CVE-2022-45442 – социально-инженерная атака через фишинговое сообщение, побуждающее пользователя вручную запустить вредоносный исполняемый файл.	1. Включить EDR-мониторинг запуска процессов, связанных с уязвимыми клиентскими библиотеками, и детектировать аномальные процессы. 2. Настроить фильтрацию вложенных исполняемых файлов и макросов на почтовых шлюзах. 3. При обнаружении эксплуатации — блокировать процессы и уведомлять ИБ-команду.	1. Применить патчи для клиентских приложений, закрывающие CVE-2025-23114, CVE-2024-39705, CVE-2024-39348, CVE-2024-27438 и CVE-2022-45442. 2. Ввести белые списки доверенных приложений и макросов (AppLocker/GPO). 3. Провести перераздачу обновлённого ПО и образовательную рассылку для пользователей.
Закрепление	Техника T1574.002 эксплуатирует уязвимости: CVE-2024-27263 – уязвимость в модуле расширений позволяет загрузить и зарегистрировать вредоносную DLL, которая автоматически подгружается при старте сервисов.	1. Мониторить загрузку и подмену DLL-библиотек в рабочих каталогах через EDR. 2. Включить проверку цифровых подписей всех загружаемых DLL. 3. При детекции сторонних или неподписанных модулей — прерывать загрузку и изолировать хост.	1. Обновить все компоненты, устраняющие CVE-2024-27263. 2. Ввести жёсткую политику загрузки DLL (whitelisting) и контроль целостности (HIDS). 3. Пересобрать критичные сервисы и модули с отключением механизма загрузки из произвольных директорий.

Продолжение таблицы А2

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Получение учетных данных	Техника T1557 эксплуатирует уязвимость CVE-2023-47742 – MITM-атака на сетевом канале передачи файла, перехватывающая и модифицирующая данные CVE-2023-7008 – уязвимость в прокси-решении, позволяющая раскрыть хэшированные пароли при аутентификации клиента	1. Развернуть IDS/IPS-сигнатуры для детектирования MITM-атак и сниффинга на протоколах аутентификации. 2. Включить мониторинг необычных попыток повторных аутентификаций и рассинхронизацию сеансов. 3. При подозрении на перехват — принудительно разрывать сессии и уведомлять пользователей.	1. Применить обновления, закрывающие CVE-2023-47742 и CVE-2023-7008. 2. Включить шифрование внутрисетевого трафика и использование TLS с проверкой сертификатов. 3. Пересоздать все сессии и сбросить скомпрометированные учётные данные.
Деструктивное воздействие	Тактика деструктивного воздействия реализуется через технику T1495: уязвимость CVE-2024-54126 – ошибка в механизме обновления микроконтроллера позволяет записать некорректный образ, приводящий к безвозвратной потере функциональности.	1. Настроить мониторинг целостности прошивки устройств (HIDS/FIM) и оповещения при изменениях. 2. Ограничить доступ к интерфейсам обновления прошивки только доверенным узлам. 3. При попытке неавторизованного обновления — блокировать канал и изолировать устройство.	1. Перепрошить оборудование с официального образа, исправляющего CVE-2024-54126. 2. Восстановить устройства из резервных конфигураций до момента атаки. 3. Провести аудит и ротацию криптографических ключей встроенных модулей безопасности.

Таблица А3 – Организационные регламенты CAPEC-701

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Первоначальный доступ	Тактика первоначального доступа реализуется через технику T1190. Эксплуатируя уязвимости: CVE-2022-48507 – уязвимость обхода проверки подлинности в модуле хранилища, позволяющая получить несанкционированный доступ к данным. CVE-2023-20900 – ошибка в веб-портале администрирования, приводящая к удалённому выполнению произвольного кода при некорректных правах доступа. Технику T1203. Эксплуатируя CVE-2023-45292 – баг в почтовом клиенте, позволяющий запускать вредоносные скрипты при открытии вложений.	1. Настроить WAF на блокировку типовых попыток эксплуатации T1190 и фильтрацию подозрительных payload в HTTP(S). 2. Включить детальный аудит веб- и клиентских запросов (URI, заголовки, тело). 3. При выявлении — изолировать узел и собрать форензику.	1. Установить последние патчи, устраняющие указанные CVE. 2. Внедрить проверку и фильтрацию вводимых данных (input validation) на стороне сервера и клиента. 3. Провести код-ревью критичных компонентов и обновить клиентские приложения.
Исполнение	Техника T1059 эксплуатирует уязвимость CVE-2022-46480 – уязвимость в PowerShell, позволяющая обойти политики выполнения скриптов Техника T1505 эксплуатирует CVE-2023-41890 – ошибка в серверном модуле базы данных, открывающая возможность выполнения произвольных SQL-команд CVE-2023-44402 – дыра в веб-фреймворке, приводящая к удалённому исполнению кода на стороне сервера	1. Мониторить запуск новых процессов через EDR, особенно нетипичные дочерние процессы интерпретаторов. 2. Ограничить исполнение скриптов и bin-файлов (Application Control). 3. При детекции — завершать подозрительные процессы и оповещать ИБ-команду.	1. Применить обновления, закрывающие CVE-2022-46480 и CVE-2023-41890. 2. Настроить AppLocker/GPO для белого списка доверенных исполняемых файлов. 3. Провести переустановку критичных компонентов с надёжных образов.

Продолжение таблицы А3

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Повышение привилегий	Техника T1068 эксплуатирует CVE-2023-51655 – переполнение буфера в драйвере сетевого адаптера, позволяющее выполнить код в контексте ядра. CVE-2023-51764 – ошибка проверки прав доступа в подсистеме управления памятью. CVE-2023-51765 – уязвимость в модуле контроля привилегий, позволяющая повысить уровень доступа до системного	1. Анализировать журналы безопасности на необычные запросы токенов/сессий (Windows Security, sudo-аудит). 2. EDR/AV — детектировать и блокировать известные эксплойт-бинарники. 3. При подозрении — изолировать хост	1. Установить все патчи для устранения указанных уязвимостей. 2. Внедрить принцип наименьших привилегий и сегментировать роли. 3. Регулярно проверять и отзывать неиспользуемые учётные записи.
Предотвращение обнаружения	Техника T1021 эксплуатирует CVE-2023-48238 – уязвимость в службе удалённого рабочего стола, обходящая аутентификацию и шифрование.	1. Настроить IDS/IPS-сигнатуры на попытки эксплойта удалённых сервисов (RDP, SSH и т.п.). 2. Мониторить нетипичные входы (геолокация, время, частота). 3. При выявлении — разрывать сессию, изолировать узел и уведомлять администраторов.	1. Закрыть или обновить уязвимые сервисы до безопасных версий. 2. Включить многофакторную аутентификацию для всех удалённых доступов. 3. Внедрить контроль доступа по сети (Network ACL, Firewall) и сегментацию периметра.
Перемещение внутри периметра	Тактика перемещение внутри периметра реализуется через технику T1185, эксплуатируя уязвимость CVE-2023-49087 – атака на cookie-хранилище браузера, позволяющая похитить сеансовые токены и выдать себя за легитимного пользователя.	1. Мониторить нетипичные HTTP-cookie и токены в веб-трафике (DLP, IDS). 2. Отслеживать массовое чтение/запись сессионных файлов браузера через EDR. 3. При подозрении — блокировать соединения, изолировать рабочую станцию и собирать артефакты.	1. Применить обновления, закрывающие CVE-2023-49087. 2. Внедрить ограничение доступа к профилям браузера через файловые ACL. 3. Провести смену всех сессионных токенов и очистку кэшей браузеров.

ПРИЛОЖЕНИЕ Б

Таблица Б1 – Паспорт уязвимости CVE-2024-27263

Идентификатор уязвимости	CVE-2024-27263 Уязвимость интерфейса dashboard программного средства автоматизации бизнес-процессов IBM Sterling B2B Integrator связана с доступом к каналу из точки, не являющейся конечной. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, реализовать атаку типа «человек посередине»
Идентификатор типа ошибка	CWE-300
Базовый вектор уязвимости	CVSS 2.0: AV:N/AC:H/Au:S/C:C/I:N/A:N CVSS 3.0: AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,9) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения

Таблица Б2 – Паспорт уязвимости CVE-2024-27438

Идентификатор уязвимости	CVE-2024-27438 Уязвимость Backend-хранилища и Frontend-обработчика запросов Apache Doris связана с загрузкой кода без проверки его целостности. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, выполнить произвольный код
Идентификатор типа ошибка	CWE-494
Базовый вектор уязвимости	CVSS 2.0: AV:N/AC:H/Au:N/C:C/I:C/A:C CVSS 3.0: AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,6) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения.

Таблица Б3 – Паспорт уязвимости CVE-2023-2904

Идентификатор уязвимости	CVE-2023-2904 Портал External Visitor Manager в HID SAFE (версии 5.8.0–5.11.3) содержит уязвимость: злоумышленник, имеющий учетные данные внутреннего пользователя, может изменить параметр visitor-id через веб-API и получить доступ к личным данным других пользователей.
Идентификатор типа ошибка	CWE-471
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:N/A:H
Уровень опасности уязвимости	Высокий (CVSS 3.1 = 7.3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Наличие API-манипуляции visitor-id подтверждает активное эксплуатирование; потенциал DoS-атаки
Способ устранения	Установить обновления HID SAFE. Если функционал External Visitor Manager не используется — временно отключить.

Таблица Б4 – Паспорт уязвимости CVE-2025-25188

Идентификатор уязвимости	CVE-2025-25188 Уязвимость функции verify_dnskey_rrset() DNS-клиента Hickory DNS (ранее Trust-DNS) связана с недостаточной проверкой подлинности данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, обойти ограничения безопасности и получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибка	CWE-345
Базовый вектор уязвимости	CVSS 2.0: AV:N/AC:L/Au:S/C:N/I:C/A:N CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N CVSS 4.0: AV:N/AC:L/AT:N/PR:L/UI:N/VC:N/VI:H/VA:N/SC:N/SI:N/SA:N/E:P
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5) Средний уровень опасности (оценка CVSS 4.0 составляет 5,7)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существуют в открытом доступе
Способ устранения	Обновление программного обеспечения

Таблица Б5 – Паспорт уязвимости CVE-2024-48916

Идентификатор уязвимости	CVE-2024-48916 Уязвимость демона radosgw системы хранения данных Ceph связана с недостаточной проверкой подлинности данных при обработке JWT-токенов. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, обойти процедуру аутентификации
Идентификатор типа ошибка	CWE-345
Базовый вектор уязвимости	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:N CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 8,5) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения

Таблица Б6 – Паспорт уязвимости CVE-2025-21511

Идентификатор уязвимости	CVE-2023-2904 Уязвимость компонента Web Runtime SEC системы управления ресурсами предприятия JD Edwards EnterpriseOne Tools связана с недостатком в механизме подтверждения источника. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, раскрыть защищаемую информацию с помощью специально созданного HTTP-запроса
Идентификатор типа ошибка	CWE-471
Базовый вектор уязвимости	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:N/A:N CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения

Таблица Б7 – Паспорт уязвимости CVE-2025-24010

Идентификатор уязвимости	CVE-2025-24010 Уязвимость механизма CORS локального сервера разработки приложений Vite связана с отсутствием проверки происхождения в WebSockets. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации путем отправки специально сформированных запросов
Идентификатор типа ошибка	CWE-346
Базовый вектор уязвимости	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:N/A:N CVSS 3.0: AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения

Таблица Б8 – Паспорт уязвимости CVE-2024-51462

Идентификатор уязвимости	CVE-2024-51462 Уязвимость средства пересылки событий системного журнала IBM QRadar WinCollect Agent связана с модификацией предполагаемых данных. Эксплуатация уязвимости может позволить нарушителю получить доступ на изменение данных
Идентификатор типа ошибка	CWE-471
Базовый вектор уязвимости	CVSS 2.0: AV:L/AC:L/Au:N/C:N/I:P/A:N CVSS 3.0: AV:L/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N
Уровень опасности уязвимости	Низкий уровень опасности (базовая оценка CVSS 2.0 составляет 2,1) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения.

Таблица Б9 – Паспорт уязвимости CVE-2024-49824

Идентификатор уязвимости	CVE-2024-49824 Уязвимость программного средства автоматизации бизнес-процессов IBM Robotic Process Automation связана с некорректной проверкой безопасности на стороне клиента. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, повысить свои привилегии
Идентификатор типа ошибка	CWE-602
Базовый вектор уязвимости	CVSS 2.0: AV:N/AC:L/Au:S/C:N/I:C/A:N CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения.

Таблица Б10 – Паспорт уязвимости CVE-2024-38325

Идентификатор уязвимости	CVE-2024-38325 Уязвимость компонента Defender Sensor службы IBM Storage Defender Data Resiliency Service (DRS) средства защиты данных IBM Storage Defender связана с некорректным шифрованием данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, реализовать атаку типа «человек посередине»
Идентификатор типа ошибка	CWE-311
Базовый вектор уязвимости	CVSS 2.0: AV:N/AC:H/Au:N/C:C/I:N/A:N CVSS 3.0: AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,4) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения.

Таблица Б11 – Паспорт уязвимости CVE-2024-21245

Идентификатор уязвимости	CVE-2024-21245 Уязвимость компонента Business Logic Infra SEC системы управления ресурсами предприятия JD Edwards EnterpriseOne Tools с недостатком в механизме подтверждения источника данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, получить несанкционированный доступ к защищаемой информации и доступ на изменение, добавление или удаление данных с помощью специально созданной HTML-страницы
Идентификатор типа ошибка	CWE-471
Базовый вектор уязвимости	CVSS 2.0: AV:N/AC:L/Au:S/C:P/I:P/A:N CVSS 3.0: AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,5) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,4)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения

Таблица Б12 – Паспорт уязвимости CVE-2024-52960

Идентификатор уязвимости	CVE-2023-2904 Уязвимость компонента GUI системы выявления и устранения угроз FortiSandbox связана с реализацией функций безопасности на стороне клиента. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнять произвольные команды
Идентификатор типа ошибка	CWE-602
Базовый вектор уязвимости	CVSS 2.0: AV:N/AC:L/Au:S/C:N/I:P/A:N CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения

Таблица Б13 – Паспорт уязвимости CVE-2024-11159

Идентификатор уязвимости	CVE-2024-11159 Портал External Visitor Manager в HID SAFE (версии 5.8.0–5.11.3) содержит уязвимость: злоумышленник, имеющий учетные данные внутреннего пользователя, может изменить параметр visitor-id через веб-API и получить доступ к личным данным других пользователей.
Идентификатор типа ошибка	CWE-311
Базовый вектор уязвимости	CVSS 2.0: AV:N/AC:H/Au:S/C:C/I:N/A:N CVSS 3.0: AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,9) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения.

Таблица Б14 – Паспорт уязвимости CVE-2024-41757

Идентификатор уязвимости	CVE-2024-41757 Портал External Visitor Manager в HID SAFE (версии 5.8.0–5.11.3) содержит уязвимость: злоумышленник, имеющий учетные данные внутреннего пользователя, может изменить параметр visitor-id через веб-API и получить доступ к личным данным других пользователей.
Идентификатор типа ошибка	CWE-311
Базовый вектор уязвимости	CVSS 2.0: AV:N/AC:H/Au:N/C:C/I:N/A:N CVSS 3.0: AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,4) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения